

الجزائرية الديمقراطية الشعبية الجمهورية
République Algérienne Démocratique et Populaire
وزارة التعليم العالي والبحث العلمي
Ministère de l'Enseignement Supérieur et de la Recherche Scientifique

المدرسة العليا للإعلام الآلي - 08 ماي 1945 – بسيدي بلعباس
Ecole Supérieure en Informatique
Mai 1945- Sidi Bel Abbès 08-



MEMOIRE

En Vue de l'obtention du diplôme de **Master**

Filière : **Informatique**

Spécialité : **Ingénierie des Systèmes Informatiques (ISI)**

Thème

Analyse de sécurité Zero Trust d'un orchestrateur d'Access
Management assisté par IA : modélisation des menaces STRIDE et
scoring semi-quantitatif inspiré de DREAD et OWASP

Présenté par :

- Mlle BENZAOUCHA Asma

Soutenu le : **08/07/2026**

Devant le jury composé de :

- Dr. ANANI Djihed
- Dr. BABA AHMED Manel
- Dr. IRATNI Naima

Présidente
Encadreur
Examinatrice

Année Universitaire : 2025 / 2026

Remerciements

Avant tout, je remercie Allah le Tout-Puissant de m'avoir donné la force, la patience et la persévérance nécessaires pour mener à bien ce travail.

Je tiens à exprimer ma profonde gratitude à mes parents pour leur amour, leur soutien constant, leurs encouragements et tous les sacrifices qu'ils ont consentis tout au long de mon parcours. Ce travail leur est dédié en témoignage de mon profond respect et de ma reconnaissance.

J'adresse mes sincères remerciements à mon encadrante, Madame Manal Baba-Ahmed, pour sa disponibilité, ses conseils précieux, son accompagnement ainsi que son soutien tout au long de la réalisation de ce projet de fin d'études.

Je tiens à exprimer ma sincère reconnaissance à l'entreprise SONATRACH pour m'avoir accueillie et m'avoir offert l'opportunité de réaliser ce travail dans un environnement professionnel à la fois enrichissant et formateur. J'adresse également mes remerciements les plus sincères aux ingénieurs de SONATRACH, notamment Monsieur Khalil Bencheikh et Madame Tamissa Samiha, pour leur disponibilité, la qualité de leur accompagnement ainsi que leur soutien précieux, même à distance.

À Wafaa,

Certaines rencontres rendent un parcours plus enrichissant qu'il ne l'aurait été autrement. Au cours de ces années d'études, ton amitié a été une source de confiance, de motivation et de sérénité. Les moments partagés, les échanges sincères et les souvenirs construits ensemble occupent une place particulière dans cette aventure.

Je te remercie pour tout ce que tu as apporté à ces années et te souhaite un avenir rempli de succès, de bonheur et de belles réalisations. Je remercie également toutes les personnes ayant contribué, de près ou de loin, à la réalisation de ce mémoire, ainsi que toute autre personne ayant apporté une aide, un conseil ou un soutien à ce travail.

Enfin, je me félicite d'avoir su rester motivée, persévérante et déterminée face aux difficultés rencontrées. Cette expérience m'a permis de grandir aussi bien sur le plan académique que personnel.

Résumé

Ce mémoire présente une analyse de sécurité Zero Trust appliquée à AegisAIMail, un orchestrateur d'Access Management assisté par intelligence artificielle. Le système étudié traite des demandes d'accès temporaires envoyées par e-mail, transforme ces demandes en représentation structurée, puis les soumet à un moteur de décision piloté par politiques. L'IA est utilisée pour comprendre et structurer le texte, mais elle ne possède aucun pouvoir d'autorisation.

Le problème étudié concerne la sécurisation d'une chaîne où une entrée non structurée et potentiellement non fiable peut conduire à une action d'accès dans un annuaire d'entreprise. Pour répondre à ce problème, le mémoire adopte une démarche fondée sur les principes Zero Trust, la modélisation des menaces STRIDE, un scoring semi-quantitatif inspiré de DREAD et OWASP, et une validation experte des scénarios critiques. Le travail s'appuie sur un diagramme de flux de données, l'identification des frontières de confiance, l'analyse des actifs à protéger et la cartographie des contrôles de sécurité.

Les résultats principaux sont une matrice STRIDE adaptée au cas AegisAIMail, un modèle de priorisation du risque, un mapping des contrôles Zero Trust et une discussion du risque résiduel. Le mémoire montre que la sécurité d'un système assisté par IA dépend moins de la performance du modèle que de la séparation entre compréhension, décision, exécution et auditabilité.

Mots-clés : Zero Trust, STRIDE, IAM, Access Management, DREAD, OWASP, scoring semi-quantitatif, IA, auditabilité, accès temporaire.

Abstract

This thesis presents a Zero Trust security analysis of AegisAIMail, an AI-assisted Access Management orchestrator. The studied system processes temporary access requests submitted by e-mail, converts them into a structured representation, and sends them to a policy-driven decision engine. Artificial intelligence is used to understand and structure the request, but it has no authorization authority.

The studied problem concerns the security of a chain where an unstructured and potentially untrusted input can lead to an access action in an enterprise directory. To address this issue, the thesis adopts an approach based on Zero Trust principles, STRIDE threat modeling, a semi-quantitative scoring model inspired by DREAD and OWASP, and expert validation of critical scenarios. The work relies on a data flow diagram, trust boundary identification, asset analysis, and security control mapping.

The main outcomes are a STRIDE matrix adapted to AegisAIMail, a risk prioritization model, a Zero Trust control mapping, and a residual risk discussion. The thesis shows that the security of an AI-assisted access system depends less on model performance than on the separation between understanding, decision, execution, and auditability.

Keywords : Zero Trust, STRIDE, IAM, Access Management, DREAD, OWASP, semi-quantitative scoring, AI, auditability, temporary access.

ملخص

يعرض هذا البحث تحليلاً أمنياً وفق مقارنة الثقة الصفيرية لنظام AegisAIMail، وهو منسق لإدارة الوصول مدعوم بالذكاء الاصطناعي. يعالج النظام طلبات الوصول المؤقتة المرسلة عبر البريد الإلكتروني، ثم يحولها إلى تمثيل منظم قبل إرسالها إلى محرك قرار يعتمد على السياسات. يستعمل الذكاء الاصطناعي لفهم الطلب وتنظيمه، لكنه لا يملك صلاحية اتخاذ قرار التفويض.

تمثل الإشكالية المدروسة في تأمين سلسلة معالجة يمكن أن تبدأ من مدخل غير منظم وغير موثوق، ثم تنتهي بإجراء فعلي داخل دليل مؤسسي مثل Directory. Active. ولمعالجة هذه الإشكالية، يعتمد البحث على مبادئ الثقة الصفيرية، ومنهجية STRIDE لنمذجة التهديدات، ونموذج تقييم شبه كمي للمخاطر مستوحى من DREAD وOWASP، إضافة إلى مراجعة خبراء للأوزان والسيناريوهات الحرجة. تعتمد الدراسة على مخطط تدفق البيانات، وتحديد حدود الثقة، وتحليل الأصول الحساسة، وربط التهديدات بالضوابط الأمنية المناسبة.

تمثل أهم نتائج هذا العمل في بناء مصفوفة STRIDE خاصة بحالة AegisAIMail، واقتراح نموذج لترتيب المخاطر حسب الأولوية، وربط الضوابط الأمنية بمبادئ الثقة الصفيرية، ومناقشة المخاطر المتبقية. يبين البحث أن أمن نظام إدارة وصول مدعوم بالذكاء الاصطناعي لا يعتمد فقط على جودة النموذج، بل على الفصل الصارم بين الفهم، واتخاذ القرار، والتنفيذ، وقابلية التدقيق.

الكلمات المفتاحية : الثقة الصفيرية، STRIDE، إدارة الهويات والوصول، DREAD، OWASP، تقييم شبه كمي، الذكاء الاصطناعي، قابلية التدقيق، الوصول المؤقت.

Table des matières

Remerciements	I
Résumé	II
Abstract	III
Résumé en arabe	IV
Liste des figures	IX
Liste des tableaux	X
Liste des acronymes	XII
1 Introduction générale	1
1.1 Introduction	1
1.2 Contexte du travail	2
1.3 Problématique	3
1.4 Objectifs du mémoire	4
1.5 Méthodologie adoptée	5
1.6 Périmètre de l'étude	5
1.7 Hypothèses de travail	6
1.8 Contributions du mémoire	7
1.9 Structure du mémoire	7
2 Concepts de base	9
2.1 Introduction	9

2.2	Gestion des identités et des accès	9
2.2.1	Définition de l'identité numérique	9
2.2.2	Authentification et autorisation	10
2.2.3	Contrôle d'accès	10
2.3	Access Management et positionnement du système étudié	11
2.4	Modèles de contrôle d'accès	12
2.4.1	RBAC	12
2.4.2	ABAC	12
2.4.3	Décision fondée sur politiques	12
2.5	Accès temporaires et Just-in-Time Access	13
2.6	Architecture Zero Trust	13
2.7	Intelligence artificielle et risques associés	14
2.8	Canal e-mail et données non structurées	15
2.9	Présentation du système étudié	16
2.10	Modélisation des menaces	16
2.10.1	Diagramme de flux de données	16
2.10.2	Actifs à protéger	17
2.10.3	Frontières de confiance	18
2.11	Méthode STRIDE	19
2.12	Évaluation du risque	20
2.12.1	Approche qualitative	20
2.12.2	Approche quantitative	21
2.12.3	Approche semi-quantitative	21
2.13	Méthodes utilisées pour guider le scoring	21
2.13.1	DREAD	21
2.13.2	OWASP Risk Rating	22
2.13.3	CVSS	22
2.13.4	NIST SP 800-30 et ISO/IEC 27005	22
2.14	Scoring semi-quantitatif retenu	23
2.15	Revue experte, consensus et méthode Delphi	24
2.15.1	Jugement expert	24

2.15.2	Consensus expert	25
2.15.3	Méthode Delphi et mini-Delphi	25
2.15.4	Méthode retenue dans ce mémoire	26
2.16	Identification des menaces STRIDE	27
2.17	Scénarios de menace détaillés	28
2.18	Priorisation des menaces	29
2.19	Analyse STRIDE détaillée par catégorie	30
2.19.1	Spoofing	30
2.19.2	Tampering	30
2.19.3	Repudiation	31
2.19.4	Information Disclosure	31
2.19.5	Denial of Service	31
2.19.6	Elevation of Privilege	31
2.20	Registre détaillé des menaces et contrôles	32
2.21	Critères d’attribution des valeurs de scoring	33
2.21.1	Justification des valeurs attribuées aux scénarios critiques	35
2.22	Scoring détaillé des scénarios	36
2.23	Contrôles Zero Trust applicables	37
2.24	Cadre conceptuel appliqué à AegisAIMail	39
2.25	Conclusion	39
3	État de l’art	41
3.1	Introduction	41
3.2	Sécurité IAM et Access Management	41
3.3	Accès temporaires, PAM et Just-in-Time Access	43
3.4	Zero Trust et décision d’accès	44
3.5	Intelligence artificielle et automatisation des demandes d’accès	45
3.6	Prompt injection et sécurité des applications LLM	45
3.7	Threat modeling : méthodes existantes	46
3.8	MITRE ATLAS et menaces contre les systèmes d’IA	47
3.9	Méthodes de scoring du risque	48
3.10	Auditabilité et non-répudiation	49

3.11 Synthèse critique de l'état de l'art	50
3.12 Positionnement de la contribution	51
3.13 Conclusion du chapitre	52
4 Conclusion générale et perspectives	54
4.1 Conclusion générale	54
4.2 Apports du mémoire	56
4.3 Limites de l'étude	57
4.4 Perspectives	58
4.5 Conclusion finale	59
Bibliographie	60

Table des figures

2.1	Composants logiques centraux d’une architecture Zero Trust, d’après NIST SP 800-207 [1].	14
2.2	Fonctions principales du NIST AI Risk Management Framework [7].	15
2.3	Diagramme de flux de données de sécurité d’AegisAIMail.	17
2.4	Figure représentant la chaîne conceptuelle de traitement sécurisé dans AegisAIMail.	39

Liste des tableaux

1.1	Synthèse personnelle des objectifs du mémoire et des résultats attendus.	4
1.2	Synthèse personnelle du périmètre et des limites du mémoire.	6
2.1	Définitions des notions IAM utilisées dans le mémoire.	11
2.2	Modèles de contrôle d'accès utilisés comme base conceptuelle.	13
2.3	Actifs critiques protégés dans AegisAIMail.	18
2.4	Frontières de confiance identifiées dans AegisAIMail.	19
2.5	Définition des catégories STRIDE dans le contexte AegisAIMail.	20
2.6	Facteurs du scoring semi-quantitatif proposé, inspirés de DREAD et OWASP Risk Rating [12].	23
2.7	Seuils de classification du risque utilisés dans le modèle proposé.	24
2.8	Matrice STRIDE principale d'AegisAIMail.	27
2.9	Registre synthétique des scénarios de menace.	29
2.10	Priorisation semi-quantitative des scénarios de menace selon le modèle proposé.	30
2.11	Registre détaillé des menaces et contrôles associés.	32
2.12	Grille d'attribution des valeurs du modèle de scoring semi-quantitatif.	35
2.13	Justification des valeurs attribuées aux scénarios critiques.	36
2.14	Scoring détaillé des scénarios de menace selon les facteurs définis dans le mo- dèle semi-quantitatif proposé.	37
2.15	Contrôles Zero Trust appliqués à AegisAIMail, alignés avec les principes du NIST SP 800-207 [1].	38
3.1	Comparaison des approches IAM et Access Management, élaborée à partir de RBAC [5] et ABAC [6].	42

3.2	Comparaison des formes d'accès dans une logique de réduction des privilèges permanents.	43
3.3	Principes Zero Trust applicables à l'Access Management, d'après NIST SP 800-207 [1].	44
3.4	Risques IA pertinents pour un orchestrateur d'accès, d'après NIST AI RMF [7], [18] et OWASP LLM Top 10 [21].	46
3.5	Comparaison des méthodes de threat modeling, à partir de Shostack [9], Shevchenko et al. [10], PASTA [22] et LINDDUN [23].	47
3.6	Comparaison des approches de scoring du risque, d'après OWASP [12], CVSS [13], NIST SP 800-30 [11] et ISO/IEC 27005 [14].	49
3.7	Éléments nécessaires à l'auditabilité d'une décision d'accès, alignés avec les contrôles d'audit du NIST SP 800-53 [25].	50
3.8	Synthèse critique des limites de l'état de l'art par rapport au cas AegisAIMail. .	51

Liste des acronymes

Acronyme	Signification
ABAC	Attribute-Based Access Control
AD	Active Directory
AI	Artificial Intelligence
API	Application Programming Interface
CVSS	Common Vulnerability Scoring System
DFD	Data Flow Diagram
DREAD	Damage, Reproducibility, Exploitability, Affected Users, Discoverability
IAM	Identity and Access Management
IA	Intelligence Artificielle
JIT	Just-in-Time
JSON	JavaScript Object Notation
LLM	Large Language Model
MFA	Multi-Factor Authentication
PAM	Privileged Access Management
PDP	Policy Decision Point
PEP	Policy Enforcement Point
RBAC	Role-Based Access Control

SIEM	Security Information and Event Management
STRIDE	Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege
ZT / ZTA	Zero Trust / Zero Trust Architecture

Chapitre 1

Introduction générale

1.1 Introduction

Ce chapitre introduit le cadre général du mémoire. Il présente progressivement le contexte de la gestion des accès temporaires, la problématique de sécurité liée au traitement des demandes par e-mail, les objectifs de l'étude, la méthodologie adoptée, le périmètre du travail, les hypothèses retenues ainsi que les principales contributions du mémoire. Cette mise en contexte permet de situer l'intérêt d'une analyse Zero Trust appliquée à un orchestrateur d'Access Management assisté par intelligence artificielle. Avant de formuler précisément la problématique, il convient d'abord de rappeler l'importance de la gestion des identités et des accès dans les systèmes d'information modernes.

La gestion des identités et des accès constitue aujourd'hui un pilier fondamental de la cybersécurité des organisations. Dans un système d'information moderne, les utilisateurs, les prestataires, les comptes techniques, les applications et les services interagissent avec un ensemble croissant de ressources numériques. Cette complexité rend la maîtrise des accès plus difficile, en particulier lorsque les demandes sont urgentes, temporaires ou formulées en langage naturel.

Les accès temporaires représentent un cas particulièrement sensible. Ils sont souvent accordés pour répondre à un besoin opérationnel ponctuel : remplacement d'un collaborateur, intervention d'un prestataire, support applicatif, mission exceptionnelle ou accès provisoire à une ressource métier. Lorsqu'ils sont mal contrôlés, ces accès peuvent devenir permanents, excessifs ou non traçables. Ils peuvent alors créer une surface d'attaque supplémentaire et favoriser l'élévation de privilèges.

Dans de nombreuses organisations, les demandes d'accès sont encore exprimées par e-mail. Ce canal est pratique et naturel pour les utilisateurs, mais il présente plusieurs limites du point de vue de la sécurité. Un e-mail peut être incomplet, ambigu, usurpé, malveillant ou contenir des instructions destinées à manipuler un système automatisé. La transformation d'un e-mail en action d'accès constitue donc une opération critique.

L'intelligence artificielle peut aider à analyser ces demandes en langage naturel. Elle peut classifier un message, identifier l'action demandée, extraire le bénéficiaire, repérer une durée ou structurer une demande sous forme de données exploitables. Cependant, l'IA introduit également de nouveaux risques : hallucination, mauvaise extraction, prompt injection, sortie non conforme ou interprétation erronée. Dans un processus d'accès, ces risques doivent être strictement encadrés.

Le présent mémoire s'intéresse à l'analyse de sécurité d'un orchestrateur d'Access Management assisté par IA, appelé AegisAIMail. Ce système traite des demandes d'accès temporaires reçues par e-mail et les soumet à une chaîne de validation, de décision et d'audit. L'objectif du mémoire n'est pas de présenter uniquement une réalisation technique, mais de proposer une analyse de sécurité structurée selon les principes Zero Trust, la méthode STRIDE et un scoring semi-quantitatif inspiré de DREAD et de l'OWASP Risk Rating.

1.2 Contexte du travail

Les approches traditionnelles de sécurité reposaient souvent sur une distinction forte entre l'intérieur et l'extérieur du réseau. Cette vision devient insuffisante dans les environnements actuels, où les accès peuvent provenir de plusieurs emplacements, terminaux, identités et applications. Le modèle Zero Trust répond à cette évolution en supprimant la confiance implicite et en imposant une vérification explicite de chaque demande d'accès [1].

Dans le domaine IAM, cette approche signifie qu'une demande d'accès ne doit jamais être acceptée uniquement parce qu'elle provient d'un canal interne ou d'un utilisateur connu. Elle doit être évaluée selon plusieurs critères : identité du demandeur, bénéficiaire, ressource cible, privilège demandé, durée, justification, sensibilité du groupe et conformité aux politiques de sécurité.

AegisAIMail s'inscrit dans ce contexte. Le système utilise l'IA pour assister la compréhens-

sion d'un e-mail, mais la décision d'accès reste contrôlée par des règles déterministes et par des garde-fous de sécurité. Cette séparation est essentielle : l'IA peut aider à structurer une demande, mais elle ne doit pas devenir une autorité d'autorisation.

Le mémoire se positionne donc à l'intersection de plusieurs domaines : Access Management, Zero Trust, sécurité de l'intelligence artificielle, modélisation des menaces, scoring du risque et auditabilité. Cette combinaison permet d'étudier un problème actuel : comment sécuriser une chaîne dans laquelle une entrée non fiable, rédigée en langage naturel, peut conduire à une action d'accès dans un système d'entreprise.

1.3 Problématique

L'automatisation du traitement des demandes d'accès par e-mail crée une chaîne de risque particulière. Le point de départ est un contenu non structuré et potentiellement non fiable. Ce contenu est ensuite analysé par un composant d'intelligence artificielle, transformé en représentation structurée, évalué par un moteur de politiques et éventuellement appliqué dans un annuaire ou un système de gestion des droits.

Cette chaîne soulève plusieurs questions de sécurité. Comment empêcher qu'un e-mail malveillant influence le comportement de l'IA ? Comment éviter qu'une extraction incorrecte conduise à un octroi d'accès ? Comment distinguer une demande légitime d'une tentative d'usurpation ou d'élévation de privilèges ? Comment prioriser les menaces identifiées ? Comment conserver une preuve fiable de la décision ?

La problématique générale du mémoire est donc formulée comme suit :

Comment analyser et réduire les risques de sécurité d'un orchestrateur d'Access Management assisté par IA, traitant des demandes d'accès temporaires par e-mail, en combinant les principes Zero Trust, la modélisation des menaces STRIDE et un scoring semi-quantitatif inspiré de DREAD et de l'OWASP Risk Rating ?

Cette problématique met en évidence trois exigences principales. La première est l'identification structurée des menaces. La deuxième est la priorisation des risques selon une méthode compréhensible et justifiable. La troisième est la définition de contrôles permettant de limiter l'impact d'une erreur, d'une manipulation ou d'une demande non conforme.

1.4 Objectifs du mémoire

L'objectif principal de ce mémoire est de proposer une analyse de sécurité Zero Trust appliquée à AegisAIMail, en utilisant STRIDE pour identifier les menaces et un scoring semi-quantitatif pour les prioriser.

Les objectifs spécifiques sont les suivants :

1. définir les concepts nécessaires à l'étude : IAM, Access Management, accès temporaires, Zero Trust, IA, threat modeling, STRIDE, scoring et auditabilité ;
2. analyser les travaux existants relatifs à la sécurité IAM, au Zero Trust, aux risques IA, aux méthodes de modélisation des menaces et aux approches de scoring du risque ;
3. représenter le système étudié à travers un diagramme de flux de données et des frontières de confiance ;
4. identifier les menaces applicables au système selon les six catégories STRIDE ;
5. proposer un scoring semi-quantitatif adapté au contexte IAM et inspiré de DREAD et de l'OWASP Risk Rating ;
6. associer les scénarios de menace aux contrôles Zero Trust pertinents ;
7. discuter le risque résiduel et les limites de l'approche ;
8. présenter des perspectives d'amélioration pour une validation plus large.

Le tableau 1.1 synthétise la relation entre les objectifs du mémoire et les résultats attendus. Ce tableau est une synthèse personnelle destinée à clarifier la démarche suivie.

Objectif	Méthode utilisée	Résultat attendu
Comprendre le domaine étudié	Analyse conceptuelle	Cadre théorique IAM, Zero Trust et IA.
Identifier les menaces	DFD et STRIDE	Liste structurée des scénarios de menace.
Prioriser les risques	Scoring semi-quantitatif	Classement des menaces par niveau de criticité.
Réduire les risques	Contrôles Zero Trust	Mapping entre menaces et mesures de sécurité.
Justifier l'approche	Revue experte et discussion critique	Validation conceptuelle et limites explicites.

Tab. 1.1: Synthèse personnelle des objectifs du mémoire et des résultats attendus.

1.5 Méthodologie adoptée

La méthodologie suivie dans ce mémoire repose sur une démarche progressive allant de la compréhension du système à la priorisation des risques.

La première étape consiste à définir le périmètre de l'étude. AegisAIMail est considéré comme un orchestrateur d'Access Management assisté par IA, et non comme une plateforme IAM complète. Le système étudié couvre la réception de l'e-mail, l'analyse du contenu, la structuration de la demande, la décision par politiques, l'exécution contrôlée et l'audit.

La deuxième étape consiste à établir le cadre conceptuel. Cette étape permet de définir les notions nécessaires : accès temporaires, Zero Trust, intelligence artificielle, DFD, STRIDE, scoring et auditabilité. Elle permet également d'intégrer l'analyse de sécurité du système dans un chapitre conceptuel cohérent.

La troisième étape consiste à réaliser un état de l'art. Cette revue permet d'identifier les apports et limites des travaux existants. Elle justifie le choix de STRIDE pour l'identification des menaces et le choix d'un scoring semi-quantitatif pour la priorisation.

La quatrième étape consiste à appliquer la démarche au cas AegisAIMail. Le système est représenté par un DFD, les frontières de confiance sont identifiées, les menaces sont classées selon STRIDE, puis les scénarios sont priorisés selon le score proposé.

La cinquième étape consiste à discuter les résultats. Cette discussion porte sur les contrôles Zero Trust, le risque résiduel, les limites de l'analyse et les perspectives d'amélioration. Le scoring proposé est présenté comme un outil de priorisation, et non comme une mesure statistique absolue.

1.6 Périmètre de l'étude

Le périmètre du mémoire couvre l'analyse de sécurité d'un processus d'accès temporaire déclenché par e-mail. Il inclut les composants conceptuels suivants : boîte e-mail, module d'analyse IA, validation de la structure, moteur de politiques, PEP, annuaire cible, audit et révocation.

En revanche, certains éléments sont considérés comme hors périmètre. Le mémoire ne vise pas à réaliser un audit complet de la messagerie, un test d'intrusion global, une évaluation statistique sur incidents réels ou une industrialisation complète en production. Ces éléments pourront faire l'objet de travaux futurs.

Le tableau 1.2 précise les éléments inclus et exclus du périmètre. Il permet d'éviter toute confusion entre le travail de Master, orienté analyse de sécurité, et le projet d'ingénierie, orienté conception et réalisation.

Élément	Inclus dans le mémoire	Hors périmètre
AegisAIMail	Analyse de sécurité du système étudié.	Présentation exhaustive de toute l'implémentation.
IA	Risques liés à l'extraction et à la structuration.	Comparaison détaillée de tous les modèles IA.
IAM	Access Management et accès temporaires.	Gestion complète du cycle de vie des identités.
Active Directory	Cible d'application conceptuelle des accès.	Audit complet de l'infrastructure AD.
Scoring	Priorisation semi-quantitative des scénarios.	Modèle probabiliste fondé sur incidents réels.
Validation	Revue experte et scénarios conceptuels.	Déploiement industriel généralisé.

Tab. 1.2: Synthèse personnelle du périmètre et des limites du mémoire.

1.7 Hypothèses de travail

L'analyse repose sur plusieurs hypothèses. Ces hypothèses permettent de clarifier les conditions dans lesquelles la démarche est appliquée.

Premièrement, l'e-mail entrant est considéré comme une donnée non fiable. Il peut contenir une demande légitime, mais il peut aussi contenir des erreurs, des ambiguïtés, une usurpation ou une instruction malveillante.

Deuxièmement, l'IA n'est pas considérée comme une autorité de décision. Elle peut extraire ou structurer des informations, mais elle ne doit pas accorder un accès par elle-même.

Troisièmement, la décision d'accès doit être produite par un moteur de politiques. Ce moteur applique des règles explicites, telles que la vérification du bénéficiaire, du groupe cible, de la durée, du type d'accès et de la sensibilité de la ressource.

Quatrièmement, l'exécution technique doit être contrôlée par un PEP. Le PEP ne doit appliquer qu'une décision autorisée, limitée et journalisée.

Cinquièmement, le scoring proposé est semi-quantitatif. Il permet de comparer et de prioriser les risques, mais il ne remplace pas une mesure statistique fondée sur une base d'incidents réels.

1.8 Contributions du mémoire

La contribution du mémoire est principalement méthodologique et analytique. Elle ne consiste pas à proposer une nouvelle méthode de sécurité totalement indépendante des travaux existants, mais à adapter et combiner des approches reconnues pour un cas spécifique : l'orchestration d'accès temporaire par e-mail assistée par IA.

Les contributions principales sont :

- une lecture Zero Trust d'un orchestrateur d'Access Management assisté par IA ;
- une représentation du système étudié à travers un DFD et des frontières de confiance ;
- une application de STRIDE aux flux, processus et actifs d'AegisAIMail ;
- un modèle de scoring semi-quantitatif inspiré de DREAD et de l'OWASP Risk Rating ;
- une priorisation des scénarios de menace selon leur impact, vraisemblance, exploitabilité, difficulté de détection et rayon d'impact ;
- un mapping entre les menaces identifiées et les contrôles Zero Trust ;
- une discussion du risque résiduel et des limites de l'approche.

Ces contributions permettent de montrer que la sécurisation d'un tel système ne dépend pas uniquement de la précision de l'IA. Elle dépend surtout de la séparation entre extraction, validation, décision, exécution et audit.

1.9 Structure du mémoire

Après ce chapitre introductif, le chapitre 2 présente les concepts de base nécessaires à la compréhension du sujet. Il introduit la gestion des identités et des accès, l'Access Management, les accès temporaires, le modèle Zero Trust, les risques liés à l'intelligence artificielle, la modélisation des menaces, STRIDE, le scoring semi-quantitatif, l'auditabilité et le cadre conceptuel appliqué à AegisAIMail.

Le chapitre 3 est consacré à l'état de l'art. Il analyse les travaux existants relatifs à la sécurité IAM, au Just-in-Time Access, au Zero Trust, à la sécurité des systèmes assistés par IA, au threat modeling, aux méthodes de scoring du risque et à l'auditabilité. Il met en évidence les limites des approches existantes lorsqu'elles sont appliquées séparément à un orchestrateur d'accès temporaire par e-mail.

Le chapitre 4 présente la conclusion générale et les perspectives. Il synthétise les apports du mémoire, discute les limites de l'analyse, rappelle le positionnement du travail par rapport au projet d'ingénierie et propose des pistes d'amélioration pour une validation plus large en environnement opérationnel.

Chapitre 2

Concepts de base

2.1 Introduction

Ce chapitre définit les concepts nécessaires à l'analyse de sécurité menée dans ce mémoire. Il ne constitue pas un état de l'art détaillé ; son rôle est de clarifier les notions utilisées par la suite et d'expliquer comment elles sont interprétées dans le cas AegisAIMail.

La progression adoptée est la suivante. La première partie présente la gestion des identités et des accès, ainsi que les modèles de contrôle d'accès. La deuxième partie introduit les accès temporaires et le modèle Zero Trust. La troisième partie définit les risques liés à l'intelligence artificielle dans une chaîne d'accès. La quatrième partie présente la modélisation des menaces, STRIDE et les diagrammes de flux de données. Enfin, la dernière partie définit les approches d'évaluation du risque, puis justifie le choix d'un scoring semi-quantitatif consolidé par une revue experte qualitative.

Cette organisation évite de répéter les mêmes idées dans plusieurs sections. Chaque notion est d'abord définie, puis reliée au contexte du mémoire.

2.2 Gestion des identités et des accès

2.2.1 Définition de l'identité numérique

Dans un système d'information, une identité numérique désigne la représentation d'une entité pouvant interagir avec des ressources informatiques. Cette entité peut être un utilisateur humain, un compte technique, une application, un service ou un équipement. L'identité est gé-

néralement décrite par un identifiant et par un ensemble d'attributs permettant de la reconnaître et de lui associer des droits.

Dans ce mémoire, l'identité numérique est importante parce qu'une demande d'accès temporaire implique au minimum deux identités : le demandeur et le bénéficiaire. Une demande ne peut donc pas être traitée correctement si le bénéficiaire n'est pas identifiable ou si son existence n'est pas vérifiable.

2.2.2 Authentification et autorisation

Le NIST définit l'authentification comme le processus permettant de vérifier l'identité d'un utilisateur, d'un processus ou d'un dispositif, souvent avant de lui permettre d'accéder à une ressource [2]. L'authentification répond donc à la question : *qui est l'entité ?*

L'autorisation répond à une question différente : *que peut faire cette entité ?* Elle consiste à déterminer si une identité authentifiée possède le droit d'accéder à une ressource ou d'exécuter une action. Le NIST associe l'autorisation à l'octroi de privilèges à une entité système pour accéder à une ressource [3].

Dans AegisAIMail, l'authentification de la messagerie est considérée comme un prérequis externe. Le cœur de l'étude porte surtout sur l'autorisation : déterminer si une demande d'accès temporaire doit être acceptée, clarifiée, revue humainement ou bloquée.

2.2.3 Contrôle d'accès

Le contrôle d'accès est le processus qui consiste à accorder ou refuser une demande d'accès à une information, un service ou une ressource. Le glossaire NIST présente le contrôle d'accès comme le fait de permettre ou refuser des demandes spécifiques d'accès à des informations ou services de traitement de l'information [4].

Dans ce mémoire, le contrôle d'accès est compris comme une chaîne composée de plusieurs étapes : compréhension de la demande, validation des champs, décision par politiques, application technique et audit. Cette chaîne est essentielle, car l'entrée initiale est un e-mail non structuré.

Le tableau 2.1 synthétise les notions IAM utilisées dans le mémoire. Il permet de distinguer les concepts de base avant d'aborder le positionnement d'AegisAIMail comme orchestrateur d'Access Management.

Concept	Définition reformulée	Interprétation dans ce mémoire
Identité numérique	Représentation d'une entité pouvant interagir avec un système.	Demandeur, bénéficiaire, compte de service ou composant applicatif.
Authentification	Vérification de l'identité déclarée d'une entité [2].	Prérequis côté messagerie et environnement d'entreprise.
Autorisation	Droit, permission ou décision indiquant ce qu'une entité est autorisée à faire [3].	Décision produite par le moteur de politiques.
Contrôle d'accès	Processus d'octroi ou de refus d'une demande d'accès à une ressource [4].	Chaîne allant de la demande email jusqu'à l'application contrôlée.
Audit	Conservation des traces permettant d'expliquer une décision.	Preuve de la demande, de la décision, de l'action et de la révocation.

Tab. 2.1: Définitions des notions IAM utilisées dans le mémoire.

2.3 Access Management et positionnement du système étudié

L'Identity and Access Management couvre un périmètre large : gestion des identités, authentification, gestion des comptes, gestion des rôles, administration des droits, contrôle d'accès et audit. L'Access Management constitue une partie plus ciblée de ce domaine. Il concerne principalement la décision d'accès, son application et sa traçabilité.

AegisAIMail n'est donc pas présenté comme une plateforme IAM complète. Il est étudié comme un orchestrateur d'Access Management. Son rôle est de traiter une demande d'accès temporaire, de la structurer, puis de la soumettre à une décision fondée sur des politiques.

Cette distinction est importante pour éviter une confusion de périmètre. Le mémoire n'analyse pas tout le cycle de vie des identités. Il analyse la sécurisation d'une chaîne d'octroi, de refus, de clarification ou de révocation d'accès temporaire.

2.4 Modèles de contrôle d'accès

2.4.1 RBAC

Le Role-Based Access Control, ou RBAC, est un modèle dans lequel les permissions sont associées à des rôles, puis les utilisateurs sont affectés à ces rôles. Le travail de Ferraiolo et Kuhn a posé les bases de ce modèle en montrant qu'il facilite l'administration des droits dans les organisations [5].

Dans le contexte AegisAIMail, RBAC est pertinent parce que les groupes Active Directory peuvent être vus comme des rôles ou ensembles de permissions. Toutefois, RBAC seul ne suffit pas, car une demande d'accès temporaire dépend aussi de la durée, de la justification, du bénéficiaire et de la sensibilité du groupe.

2.4.2 ABAC

L'Attribute-Based Access Control, ou ABAC, est défini par le NIST comme une méthode dans laquelle une demande d'accès est accordée ou refusée selon des attributs du sujet, de l'objet, de l'action et éventuellement de l'environnement [6]. Cette approche permet des décisions plus contextuelles que RBAC.

Dans ce mémoire, ABAC aide à comprendre pourquoi une décision d'accès ne doit pas dépendre uniquement du groupe demandé. Elle doit aussi prendre en compte des attributs comme le type de bénéficiaire, la durée, la ressource, la justification et le niveau de sensibilité.

2.4.3 Décision fondée sur politiques

Une approche fondée sur politiques consiste à exprimer les conditions d'accès sous forme de règles explicites. Dans une architecture de contrôle d'accès, on distingue généralement le Policy Decision Point, qui prend la décision, et le Policy Enforcement Point, qui applique cette décision. Le guide NIST sur ABAC présente ces composants dans les architectures de décision d'accès [6].

Dans AegisAIMail, cette séparation est fondamentale. L'IA peut extraire des informations, mais elle ne décide pas. La décision doit être prise par des politiques explicites, puis appliquée par un PEP contrôlé.

Le tableau 2.2 compare les modèles utilisés comme base conceptuelle. Il met en évidence que le mémoire ne retient pas un modèle unique, mais une lecture hybride adaptée aux demandes temporaires.

Modèle	Définition	Utilisation dans le mémoire
RBAC	Attribution de permissions à des rôles ou groupes [5].	Comprendre les groupes comme supports de droits.
ABAC	Décision fondée sur des attributs du sujet, de l'objet, de l'action et du contexte [6].	Intégrer durée, bénéficiaire, justification et sensibilité.
Policy-Based Access	Décision d'accès exprimée par des règles explicites.	Séparer l'extraction IA de la décision de sécurité.

Tab. 2.2: Modèles de contrôle d'accès utilisés comme base conceptuelle.

2.5 Accès temporaires et Just-in-Time Access

Un accès temporaire est un droit accordé pour une durée limitée afin de répondre à un besoin ponctuel. Dans ce mémoire, un accès temporaire est défini par un bénéficiaire, une ressource, un privilège, une justification, une durée, une décision et une trace d'audit.

Le Just-in-Time Access désigne une logique d'accès dans laquelle le droit est accordé au moment du besoin, puis retiré après expiration. Cette approche réduit les privilèges permanents et s'inscrit dans le principe du moindre privilège.

Dans AegisAIMail, cette notion est centrale. Une demande sans durée explicite, sans bénéficiaire identifiable ou sans ressource connue ne doit pas être exécutée automatiquement. Le caractère temporaire ne suffit pas à rendre l'accès sûr ; il faut aussi garantir sa validation, son audit et sa révocation.

2.6 Architecture Zero Trust

Le NIST définit le Zero Trust comme un ensemble de concepts visant à déplacer les défenses depuis un périmètre réseau statique vers les utilisateurs, les actifs et les ressources. Le NIST précise également qu'aucune confiance implicite ne doit être accordée uniquement à cause de la localisation réseau ou de la propriété de l'actif [1].

Dans ce mémoire, Zero Trust est interprété comme une règle de gouvernance de la décision

d'accès : aucune demande ne doit être considérée comme fiable par défaut. Même si l'e-mail semble interne, même si le demandeur est connu, et même si l'IA extrait des champs corrects, la demande doit rester soumise aux politiques.

La figure 2.1 est utilisée pour présenter les composants logiques Zero Trust du NIST. Elle sert à introduire la séparation entre décision d'accès et application technique de cette décision.

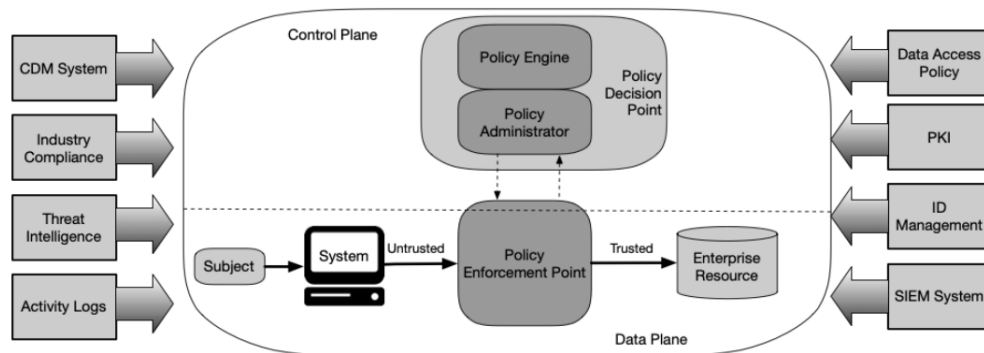


Fig. 2.1: Composants logiques centraux d'une architecture Zero Trust, d'après NIST SP 800-207 [1].

Dans AegisAIMail, cette logique conduit à quatre règles : l'e-mail est non fiable par défaut, l'IA n'est pas autorité d'accès, la décision est produite par politiques, et l'exécution est limitée par un PEP.

2.7 Intelligence artificielle et risques associés

Le NIST AI Risk Management Framework présente la gestion du risque IA comme une démarche visant à identifier, mesurer et gérer les risques des systèmes d'intelligence artificielle. Le cadre AI RMF repose notamment sur quatre fonctions : Govern, Map, Measure et Manage [7].

Dans ce mémoire, l'IA est utilisée comme composant d'assistance. Elle peut aider à comprendre l'e-mail et à produire une représentation structurée, mais elle ne doit pas décider de l'accès. Cette limitation est essentielle, car les systèmes IA peuvent produire des erreurs, des sorties non conformes ou être influencés par des entrées adversariales.

Les principaux risques IA considérés sont les suivants :

- **hallucination** : production d'une information non présente dans l'e-mail ;

- **mauvaise extraction** : identification incorrecte du bénéficiaire, du groupe ou de la durée ;
- **prompt injection** : tentative d'influencer le modèle par une instruction malveillante ;
- **sortie non conforme** : génération d'un JSON invalide ou contenant des champs inattendus ;
- **fuite d'information** : exposition de règles, groupes ou données internes.

La figure 2.2 est utilisée pour présenter le cœur du cadre NIST AI RMF. Elle rappelle que la gestion du risque IA ne concerne pas uniquement la précision du modèle, mais aussi sa gouvernance et son contrôle.



Fig. 2.2: Fonctions principales du NIST AI Risk Management Framework [7].

2.8 Canal e-mail et données non structurées

Un e-mail est une donnée non structurée. Il peut contenir des phrases libres, plusieurs demandes, des informations manquantes ou des ambiguïtés. Dans un système d'accès, ce caractère non structuré représente un risque, car une mauvaise interprétation peut conduire à une décision

incorrecte.

Dans ce mémoire, le canal e-mail est donc considéré comme une entrée non fiable. Le rôle du système n'est pas de faire confiance à l'e-mail, mais de le transformer en demande structurée, puis de valider cette demande avant toute décision.

Cette section introduit une distinction importante : la structuration n'est pas l'autorisation. Transformer un e-mail en JSON ne signifie pas que l'accès doit être accordé. Le JSON doit être vérifié par un schéma, confronté au catalogue d'accès et évalué par politiques.

2.9 Présentation du système étudié

AegisAIMail est un orchestrateur d'Access Management assisté par IA. Le système reçoit une demande d'accès temporaire par e-mail, la transforme en JSON IAM, puis transmet la demande à un moteur de décision. Le PEP exécute uniquement les décisions autorisées.

Le système est structuré en quatre zones : entrée non fiable, traitement interne, décision de sécurité et application des accès. Cette séparation facilite l'analyse des frontières de confiance.

2.10 Modélisation des menaces

La modélisation des menaces est une démarche permettant d'identifier ce qui peut mal se passer dans un système, quels actifs sont exposés et quelles attaques sont plausibles. Le NIST SP 800-154 présente le threat modeling comme une approche d'analyse des menaces centrée sur les systèmes, les données et les interactions [8].

Dans ce mémoire, la modélisation des menaces sert à analyser la chaîne complète : e-mail, extraction IA, JSON, décision, PEP, annuaire et audit.

2.10.1 Diagramme de flux de données

Un Data Flow Diagram, ou DFD, représente les entités externes, les processus, les flux de données et les magasins de données d'un système. Dans une analyse de sécurité, le DFD permet aussi d'identifier les frontières de confiance.

La figure 2.3 présente le DFD de sécurité d'AegisAIMail. Ce schéma sert de support à l'identification des actifs, des frontières de confiance et des menaces STRIDE.

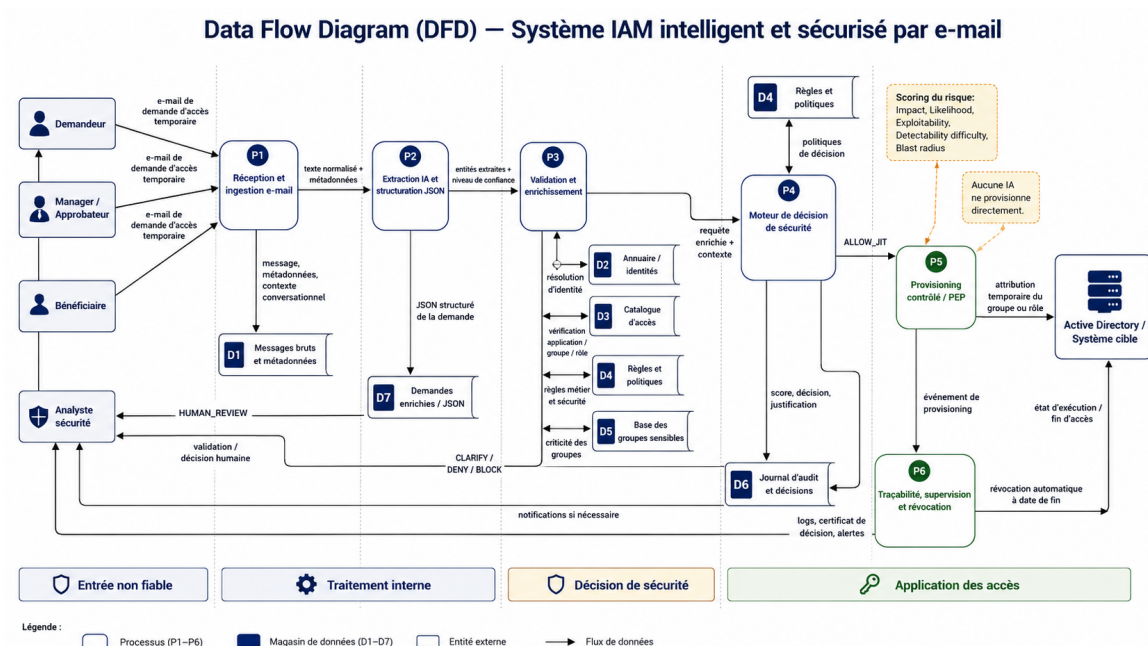


Fig. 2.3: Diagramme de flux de données de sécurité d'AegisAIMail.

2.10.2 Actifs à protéger

Dans l'approche Zero Trust adoptée par AegisAIMail, chaque composant manipulant une demande d'accès est considéré comme un actif critique. L'identification de ces actifs permet d'évaluer les risques associés et de définir les mesures de sécurité nécessaires pour prévenir toute compromission du processus de gestion des accès.

Le tableau 2.3 présente les principaux actifs manipulés par AegisAIMail. Cette identification permet de comprendre quels éléments doivent être protégés avant d'appliquer l'analyse STRIDE.

Actif	Rôle	Risque principal
E-mail reçu	Point d'entrée de la demande.	Usurpation, injection, manipulation.
JSON IAM	Représentation structurée.	Altération ou champ inventé.
Catalogue d'accès	Référentiel de droits autorisés.	Mauvais mapping ressource/groupe.
Moteur de décision	Autorisation par politiques.	Contournement ou mauvaise configuration.
PEP	Application technique.	Exécution non autorisée.
Active Directory	Cible d'exécution.	Ajout à un groupe critique.
Audit	Preuve de décision.	Suppression, altération ou réputation.

Tab. 2.3: Actifs critiques protégés dans AegisAIMail.

2.10.3 Frontières de confiance

Une frontière de confiance est un point où le niveau de confiance change. Par exemple, le passage entre un utilisateur externe et la boîte e-mail constitue une frontière, car le contenu reçu ne peut pas être supposé fiable. De même, le passage entre l'IA et le moteur de décision est une frontière importante : une extraction IA ne doit pas être considérée comme une décision.

Dans AegisAIMail, les frontières principales sont : l'entrée e-mail, la sortie IA, le JSON validé, le moteur de décision, le PEP et l'annuaire cible.

Le tableau 2.4 détaille ces frontières de confiance. Il précise, pour chaque passage sensible, le risque associé et le contrôle attendu afin d'éviter qu'une donnée non fiable soit transformée directement en action d'accès.

Frontière de confiance	Risque associé	Contrôle attendu
Utilisateur / boîte e-mail	L'e-mail peut être usurpé, incomplet, ambigu ou malveillant.	Considérer l'e-mail comme non fiable, vérifier le demandeur et détecter les contenus adversariaux.
Boîte e-mail / module d'ingestion	Le message peut contenir plusieurs demandes ou des données non structurées.	Prétraitement, normalisation, filtrage et conservation de l'e-mail original.
Ingestion / analyse IA	L'IA peut mal interpréter le contenu ou produire une extraction incorrecte.	Limiter l'IA à l'extraction, interdire toute décision automatique par le modèle.
Analyse IA / JSON IAM	Le JSON peut contenir des champs manquants, inventés ou non conformes.	Validation par schéma strict, rejet des champs inattendus et contrôle des valeurs extraites.
JSON IAM / moteur de décision	Une demande structurée peut rester non conforme aux politiques.	Vérification du bénéficiaire, du groupe cible, de la durée, de la justification et du catalogue d'accès.
Moteur de décision / PEP	Une décision ne doit pas être exécutée si elle n'est pas explicitement autorisée.	Deny-by-default, contrôle d'état de décision et exécution uniquement des décisions autorisées.
PEP / Active Directory	Une action technique peut modifier réellement les droits d'un utilisateur.	Limitation par allowlist, blocklist des groupes sensibles, droits minimaux du compte de service.
Système / journaux d'audit	Les traces peuvent être absentes, incomplètes ou altérées.	Journalisation de l'e-mail, du JSON, de la décision, de l'action exécutée et de la révocation.

Tab. 2.4: Frontières de confiance identifiées dans AegisAIMail.

2.11 Méthode STRIDE

STRIDE est une méthode de classification des menaces qui distingue six catégories : Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service et Elevation of Privilege. Elle est couramment utilisée avec les DFD pour identifier les menaces associées aux processus, flux et magasins de données [9], [10].

STRIDE est retenue dans ce mémoire, car AegisAIMail peut être représenté par un DFD clair : entités externes, processus, magasins de données et flux. Les six catégories STRIDE couvrent les principaux risques du système : usurpation d'e-mail, altération du JSON, répudia-

tion de décision, fuite d'information, saturation et élévation de privilège.

Le tableau 2.5 définit les six catégories dans le contexte du mémoire. Cette définition sert de transition entre les concepts généraux de threat modeling et l'identification concrète des menaces d'AegisAIMail.

Catégorie	Définition	Exemple dans AegisAIMail
Spoofing	Usurpation d'une identité ou d'un composant.	E-mail envoyé en se faisant passer pour un demandeur légitime.
Tampering	Modification non autorisée d'une donnée ou d'un flux.	Altération du JSON IAM ou du groupe cible.
Repudiation	Possibilité de nier une action faute de preuve.	Absence de trace fiable de la demande ou de la décision.
Information Disclosure	Divulgaration d'informations sensibles.	Exposition de groupes, règles, bénéficiaires ou journaux.
Denial of Service	Indisponibilité ou saturation d'un composant.	Envoi massif d'e-mails ou demandes volontairement ambiguës.
Elevation of Privilege	Obtention de privilèges supérieurs à ceux autorisés.	Demande vers un groupe critique ou excessif.

Tab. 2.5: Définition des catégories STRIDE dans le contexte AegisAIMail.

2.12 Évaluation du risque

Le NIST SP 800-30 définit l'évaluation du risque comme un processus d'identification, d'estimation et de priorisation des risques de sécurité de l'information [11]. Cette définition implique trois étapes : identifier les scénarios, estimer leur importance et les classer pour guider la réponse.

Dans ce mémoire, l'évaluation du risque intervient après STRIDE. STRIDE identifie les menaces, mais ne dit pas automatiquement lesquelles doivent être traitées en priorité. Le scoring est donc utilisé pour ordonner les scénarios.

2.12.1 Approche qualitative

Une approche qualitative utilise des catégories non numériques, par exemple faible, moyen, élevé ou critique. Selon le NIST SP 800-30, les approches qualitatives s'appuient sur des niveaux ou catégories non numériques [11].

Cette approche est facile à communiquer, mais elle peut manquer de précision lorsqu'il faut comparer deux scénarios proches.

2.12.2 Approche quantitative

Une approche quantitative cherche à estimer le risque à partir de valeurs mesurables : fréquence d'incident, probabilité d'exploitation, coût moyen, durée d'exposition ou nombre d'actifs affectés. Le NIST souligne que la quantification peut améliorer la rigueur, mais qu'elle devient fragile lorsque les valeurs reposent sur des hypothèses incertaines [11].

Dans notre contexte, cette approche n'a pas été retenue comme méthode principale, car il n'existait pas de base historique d'incidents IAM suffisamment représentative pour calibrer les probabilités et les impacts.

2.12.3 Approche semi-quantitative

Une approche semi-quantitative utilise des échelles numériques ou des intervalles pour représenter des niveaux de risque. Le NIST indique que ce type d'approche peut combiner les avantages des approches qualitatives et quantitatives, en facilitant la communication et la comparaison relative des risques [11].

C'est l'approche retenue dans ce mémoire. Elle permet de classer les scénarios sans prétendre produire une probabilité exacte.

2.13 Méthodes utilisées pour guider le scoring

Cette section définit les méthodes utilisées comme inspiration. Elle ne constitue pas un état de l'art détaillé ; elle explique simplement le rôle de chaque méthode dans la construction du modèle.

2.13.1 DREAD

DREAD est une méthode de notation multi-facteurs historiquement utilisée dans le threat modeling. Son nom renvoie à cinq dimensions : Damage, Reproducibility, Exploitability, Affected Users et Discoverability.

Dans ce mémoire, DREAD est utilisé comme inspiration conceptuelle, car il montre l'intérêt d'évaluer un scénario selon plusieurs dimensions. Il n'est pas repris tel quel, car certains facteurs doivent être adaptés au contexte IAM.

2.13.2 OWASP Risk Rating

L'OWASP Risk Rating Methodology repose sur l'idée que le risque peut être estimé à partir de la vraisemblance et de l'impact. OWASP précise également que le modèle doit être personnalisé selon le contexte de l'organisation [12].

Dans ce mémoire, OWASP justifie l'usage des dimensions *vraisemblance* et *impact*, ainsi que l'adaptation des facteurs au contexte AegisAIMail.

2.13.3 CVSS

CVSS est un système de notation des vulnérabilités techniques. FIRST indique que CVSS capture les caractéristiques techniques principales des vulnérabilités logicielles, matérielles et firmware, et produit un score numérique de sévérité [13].

Dans ce mémoire, CVSS n'est pas utilisé directement, car les scénarios étudiés ne sont pas uniquement des vulnérabilités techniques. Ils concernent aussi un processus métier d'accès par e-mail. CVSS sert donc de référence de structuration, mais pas de formule principale.

2.13.4 NIST SP 800-30 et ISO/IEC 27005

Le NIST SP 800-30 fournit un cadre général pour conduire des évaluations de risque, notamment par l'identification des menaces, des vulnérabilités, de la vraisemblance et de l'impact [11]. ISO/IEC 27005 fournit également un cadre de gestion des risques de sécurité de l'information [14].

Ces cadres ne donnent pas une formule unique directement applicable à AegisAIMail. Ils justifient plutôt une démarche structurée, explicite et contextualisée.

2.14 Scoring semi-quantitatif retenu

Le score proposé dans ce mémoire est un outil de priorisation. Il n'a pas pour objectif de mesurer statistiquement la probabilité réelle d'un incident. Il sert à comparer les scénarios identifiés par STRIDE selon des critères communs.

Le modèle utilise cinq facteurs : impact, vraisemblance, exploitabilité, difficulté de détection et rayon d'impact. Chaque facteur est noté de 1 à 5. Le tableau 2.6 présente leur définition.

Facteur	Poids	Définition dans ce mémoire
Impact	0,35	Gravité des conséquences en cas de succès du scénario.
Vraisemblance	0,25	Réalisme du scénario dans le contexte d'un flux de demande par e-mail.
Exploitabilité	0,20	Facilité pratique avec laquelle le scénario peut être exploité.
Difficulté de détection	0,10	Niveau de difficulté à repérer le scénario avant ou après l'action.
Rayon d'impact	0,10	Étendue des utilisateurs, ressources, groupes ou systèmes affectés.

Tab. 2.6: Facteurs du scoring semi-quantitatif proposé, inspirés de DREAD et OWASP Risk Rating [12].

Le score global est calculé comme suit :

$$Score = 20 \times (0,35I + 0,25V + 0,20E + 0,10D + 0,10R)$$

où I représente l'impact, V la vraisemblance, E l'exploitabilité, D la difficulté de détection et R le rayon d'impact. La notation V est retenue dans les tableaux afin d'éviter une confusion avec la lettre L , souvent utilisée pour d'autres variables.

Les seuils utilisés sont présentés dans le tableau 2.7. Ils transforment le score numérique en niveau de risque exploitable.

Score	Niveau	Réponse générale
20–44	Faible	Acceptable sous contrôles standards.
45–64	Moyen	Clarification ou contrôle complémentaire.
65–79	Élevé	Revue humaine ou blocage selon le contexte.
80–100	Critique	Blocage par défaut et analyse de sécurité.

Tab. 2.7: Seuils de classification du risque utilisés dans le modèle proposé.

Le choix d’un modèle semi-quantitatif est lié à une limite méthodologique assumée : l’absence d’une base historique d’incidents IAM exploitable. Une approche purement quantitative aurait nécessité des données réelles sur les fréquences d’incidents, les coûts, les probabilités d’exploitation et les impacts observés. En l’absence de ces données, un score quantitatif aurait donné une impression de précision non justifiée.

Certains scénarios peuvent cependant déclencher une décision de blocage indépendamment du score numérique obtenu. C’est le cas, par exemple, des demandes visant un groupe critique, des appels au PEP hors workflow ou des structures JSON non conformes. Le score sert donc à prioriser le risque, tandis que les règles dures servent à empêcher certaines actions interdites par principe.

2.15 Revue experte, consensus et méthode Delphi

2.15.1 Jugement expert

Le jugement expert désigne l’utilisation de l’expérience, des connaissances et du retour pratique d’un spécialiste ou d’un praticien expérimenté afin d’évaluer une situation lorsque les données disponibles sont limitées ou insuffisamment représentatives. Dans une analyse de risque, il permet notamment de qualifier des scénarios, de discuter des hypothèses, d’apprécier la pertinence des facteurs retenus et de vérifier la cohérence opérationnelle d’un modèle d’évaluation.

Dans le cadre de ce mémoire, le jugement expert est mobilisé pour consolider le modèle de scoring semi-quantitatif proposé. Il ne remplace pas des données statistiques issues d’incidents réels, mais il permet de réduire le caractère arbitraire du choix des facteurs, des pondérations

et des seuils de classification. Il constitue ainsi un appui méthodologique pour vérifier que le modèle proposé reste cohérent avec les contraintes d'un contexte IAM et d'un processus d'accès temporaire.

2.15.2 Consensus expert

Le consensus expert correspond à un accord obtenu entre plusieurs experts après une consultation ou une discussion structurée. Il suppose généralement l'intervention d'un panel composé de plusieurs profils, une confrontation des points de vue et une méthode permettant d'identifier des convergences sur les hypothèses, les critères ou les priorités retenues.

Dans ce mémoire, le terme *consensus expert* n'est pas retenu comme désignation de la méthode principale, car la démarche n'a pas été conduite avec un panel complet de plusieurs experts indépendants. La formulation la plus appropriée est donc celle de *revue technique qualitative* ou de *consultation experte individuelle*. Cette précision est importante afin de ne pas présenter la validation réalisée comme un consensus formel.

2.15.3 Méthode Delphi et mini-Delphi

La méthode Delphi est une méthode structurée de consultation d'experts développée notamment par Dalkey et Helmer. Elle repose sur plusieurs cycles de questionnaires, une synthèse des réponses entre les tours et une recherche progressive de convergence des avis [15]. Des guides méthodologiques récents présentent également Delphi comme une démarche permettant de conduire et d'évaluer des panels d'experts de manière structurée [16].

Une méthode mini-Delphi reprend la même logique générale, mais avec un dispositif plus réduit : un nombre limité de participants, moins de cycles d'échange ou une procédure plus courte. Elle peut être adaptée à un travail académique appliqué, à condition de documenter clairement le nombre d'experts, les questions posées, les réponses obtenues et les éventuels ajustements réalisés.

Dans ce mémoire, une mini-Delphi n'a pas été conduite formellement. Elle est mentionnée comme une alternative méthodologique possible pour une validation plus robuste du modèle de scoring. Une telle démarche pourrait être envisagée dans des travaux futurs en impliquant plusieurs profils complémentaires, par exemple des responsables IAM, cybersécurité, Active Directory, SOC et métiers.

2.15.4 Méthode retenue dans ce mémoire

La méthode effectivement retenue dans ce mémoire correspond à une consultation experte individuelle, réalisée sous forme de revue technique qualitative. Cette revue a été menée avec l'accompagnement de Monsieur Khalil Bencheikh, ingénieur systèmes expérimenté au sein de l'organisme d'accueil et doctorant dans un domaine lié aux réseaux et systèmes distribués. Son profil professionnel, orienté systèmes, réseaux, support informatique, Active Directory et environnements d'entreprise, a permis d'apporter un regard opérationnel sur la cohérence de l'analyse proposée.

Cette consultation ne s'est pas limitée à un échange ponctuel. Elle s'est inscrite dans l'accompagnement global du stage, durant lequel plusieurs aspects du sujet ont été discutés progressivement : le périmètre du système étudié, les contraintes réelles des environnements d'entreprise, les risques associés aux accès temporaires, la séparation entre extraction par IA et décision de sécurité, ainsi que la logique de priorisation des scénarios de menace.

Afin de structurer cette revue, deux supports méthodologiques ont été préparés et transmis pour discussion. Le premier rappelait le thème, la logique STRIDE, l'adaptation de DREAD et de l'OWASP Risk Rating au contexte IAM, ainsi que la chaîne de traitement sécurisée du système. Le second détaillait la formule de scoring proposée, les facteurs retenus, les pondérations, l'échelle de notation et les questions destinées à guider la validation qualitative du modèle.

La démarche retenue peut être résumée comme suit :

1. identification des actifs, des flux et des frontières de confiance du système ;
2. identification des scénarios de menace à partir du DFD et de la méthode STRIDE ;
3. choix des facteurs de scoring à partir de DREAD, de l'OWASP Risk Rating et de la logique d'évaluation du risque ;
4. adaptation des facteurs au contexte IAM : impact, vraisemblance, exploitabilité, difficulté de détection et rayon d'impact ;
5. définition d'une pondération initiale selon la criticité des risques d'accès ;
6. discussion qualitative avec un praticien expérimenté du domaine ;
7. consolidation des choix retenus et explicitation des limites de validation.

Les éléments relus et discutés ont principalement concerné la pertinence des scénarios STRIDE, la cohérence des cinq facteurs du scoring, la justification des pondérations, l'échelle de notation

de 1 à 5, les seuils de classification du risque, ainsi que l'adéquation entre les scénarios identifiés et les contrôles Zero Trust proposés.

Cette revue a permis de vérifier que le scoring proposé n'était pas défini de manière totalement arbitraire. Il repose sur des méthodes existantes, une adaptation au contexte IAM et une discussion qualitative avec un praticien expérimenté. Toutefois, cette démarche ne constitue pas une validation statistique, ni un consensus expert formel. Elle doit être interprétée comme une validation qualitative contextualisée, utile pour renforcer la cohérence opérationnelle du modèle, mais insuffisante pour établir une généralisation définitive.

Les principales limites de cette validation sont liées au recours à un seul praticien, à l'absence de panel indépendant, à l'absence de cycles Delphi formalisés et à l'absence de calibration sur des données historiques d'incidents IAM. Une validation plus robuste nécessiterait plusieurs experts, des échanges structurés en plusieurs tours, une comparaison des avis et, idéalement, des données anonymisées issues d'environnements opérationnels réels.

2.16 Identification des menaces STRIDE

À partir des actifs précédemment identifiés, une analyse des menaces est réalisée afin de déterminer les risques de sécurité auxquels AegisAIMail est exposé. Chaque composant du système est évalué au regard des catégories STRIDE afin de mettre en évidence les menaces pouvant affecter l'intégrité des décisions, la confidentialité des informations, la disponibilité des services ou le respect du principe du moindre privilège.

Le tableau 2.8 applique les catégories STRIDE aux principaux composants du système. Il permet de passer d'une définition générale de STRIDE à une première identification des menaces concrètes dans AegisAIMail.

Tab. 2.8: Matrice STRIDE principale d'AegisAIMail.

STRIDE	Composant	Menace	Impact
Spoofing	E-mail entrant	Usurpation de l'identité du demandeur.	Demande frauduleuse.

STRIDE	Composant	Menace	Impact
Spoofing	Service interne	Usurpation d'un composant applicatif.	Appel non autorisé.
Tampering	E-mail	Modification du bénéficiaire ou de la ressource.	Accès incorrect.
Tampering	JSON IAM	Modification du groupe cible ou de la durée.	Octroi non conforme.
Repudiation	Audit	Suppression ou modification des logs.	Absence de preuve.
Information Disclosure	Logs	Exposition de données internes.	Fuite d'information.
Information Disclosure	Catalogue	Révélation des groupes sensibles.	Aide à l'attaquant.
Denial of Service	Ingestion	Envoi massif d'e-mails.	Saturation du traitement.
Denial of Service	IA	Requêtes longues ou ambiguës.	Dégradation de service.
Elevation of Privilege	PEP / AD	Demande vers un groupe critique.	Escalade de privilège.
Elevation of Privilege	Catalogue	Mauvais mapping vers un groupe plus permissif.	Accès excessif.

2.17 Scénarios de menace détaillés

La matrice STRIDE donne une vision synthétique. Pour prioriser correctement, chaque menace doit être reformulée comme un scénario opérationnel. Un scénario précise l'acteur, le vecteur, l'actif touché, les conditions de réussite et l'effet attendu.

Le tableau 2.9 reformule les menaces identifiées sous forme de scénarios opérationnels.

Cette étape facilite ensuite la priorisation, car chaque menace devient un cas analysable selon des critères communs.

Tab. 2.9: Registre synthétique des scénarios de menace.

ID	Scénario	Condition de réussite	Conséquence
T1	E-mail usurpant un demandeur légitime.	Absence de contrôle d'identité ou revue insuffisante.	Création d'une demande frauduleuse.
T2	Prompt injection dans le corps de l'e-mail.	Le modèle confond instruction et donnée.	JSON orienté par l'attaquant.
T3	Altération du JSON IAM avant décision.	Validation de schéma absente ou permissive.	Modification du bénéficiaire ou du groupe.
T4	Demande vers un groupe critique.	Blocklist absente ou mal configurée.	Élévation de privilège.
T5	Saturation par e-mails massifs.	Absence de quota ou filtrage.	Indisponibilité du pipeline.
T6	Suppression de traces d'audit.	Logs non protégés.	Répudiation d'une action.
T7	Mauvais mapping dans le catalogue.	Gouvernance insuffisante.	Accès plus large que prévu.
T8	Durée excessive ou absente.	Contrôle de durée absent.	Persistance de privilège.

2.18 Priorisation des menaces

Le tableau 2.10 présente une première priorisation synthétique des scénarios de menace. Il utilise les facteurs de scoring définis précédemment afin de classer les scénarios selon leur niveau de risque.

Scénario	I	E	V	D	R	Score	Niveau
Usurpation d'un demandeur par e-mail	5	4	4	4	4	87	Critique
Altération du JSON IAM	5	4	4	4	4	87	Critique
Demande vers un groupe critique	5	3	4	4	5	84	Critique
Prompt injection visant les règles	4	4	3	3	3	72	Élevé
Saturation par e-mails massifs	3	4	4	2	3	67	Élevé
Fuite d'informations dans les logs	3	2	3	3	3	55	Moyen
Demande incomplète non malveillante	1	4	2	1	1	39	Faible

Tab. 2.10: Priorisation semi-quantitative des scénarios de menace selon le modèle proposé.

2.19 Analyse STRIDE détaillée par catégorie

Cette section complète la matrice précédente par une lecture plus détaillée de chaque catégorie STRIDE. L'objectif est de montrer comment chaque famille de menace se manifeste concrètement dans la chaîne de traitement d'AegisAIMail.

2.19.1 Spoofing

Le spoofing concerne l'usurpation d'identité. Dans AegisAIMail, le scénario le plus direct est l'envoi d'un e-mail qui semble provenir d'un demandeur légitime. Le risque est renforcé lorsque le workflow accorde une forte confiance à l'adresse de l'expéditeur. Même si l'e-mail provient d'un domaine interne, la compromission d'une boîte utilisateur reste possible.

La mitigation ne peut donc pas se limiter à vérifier le domaine. Il faut vérifier la cohérence métier de la demande, le bénéficiaire, la ressource et le niveau de sensibilité. Les demandes sensibles doivent être orientées vers une revue humaine ou un propriétaire de ressource.

2.19.2 Tampering

Le tampering désigne la modification non autorisée des données. Trois données sont particulièrement sensibles : le contenu de l'e-mail, le JSON IAM et le catalogue d'accès. Une modification du bénéficiaire, du groupe cible ou de la durée peut transformer une demande légitime en demande dangereuse.

La validation du schéma JSON, la normalisation des champs et la journalisation des versions intermédiaires permettent de limiter ce risque. Le système doit également éviter d'accepter des

champs non prévus par le schéma, car ils pourraient être utilisés pour influencer une étape ultérieure.

2.19.3 Repudiation

La répudiation apparaît lorsqu'un acteur peut nier une action. Dans AegisAIMail, un demandeur pourrait nier avoir envoyé une demande, un reviewer pourrait contester une approbation, ou un administrateur pourrait ne pas pouvoir prouver qu'une action a été exécutée correctement. La non-répudiation repose donc sur la conservation de preuves : e-mail source, extraction, décision, reviewer, action technique et horodatage.

2.19.4 Information Disclosure

Les logs, le catalogue et les décisions peuvent contenir des informations sensibles : noms de groupes, ressources internes, bénéficiaires, règles de décision et contexte métier. Une fuite de ces données peut faciliter une attaque ciblée. La protection des journaux et la minimisation des informations exposées sont donc nécessaires.

2.19.5 Denial of Service

Le déni de service peut viser la boîte e-mail, le pipeline d'ingestion, le modèle IA ou le moteur de décision. Un attaquant peut envoyer un grand nombre d'e-mails, des e-mails très longs ou des demandes ambiguës augmentant la charge de traitement. La mitigation repose sur les quotas, la limitation de taille, les files d'attente, le filtrage et la supervision.

2.19.6 Elevation of Privilege

L'élévation de privilège est le risque le plus critique dans un système d'accès. Elle peut se produire si une demande vise un groupe critique, si le catalogue contient un mauvais mapping ou si le PEP exécute une action hors allowlist. La blocklist, le deny-by-default et la limitation du compte de service sont donc des contrôles essentiels.

2.20 Registre détaillé des menaces et contrôles

Le tableau 2.11 complète l'analyse en associant chaque scénario à un contrôle principal et à un risque résiduel. Il permet de montrer que la réduction du risque ne repose pas seulement sur le score, mais aussi sur les mesures de sécurité appliquées.

Tab. 2.11: Registre détaillé des menaces et contrôles associés.

ID	Type	Scénario	Contrôle principal	Risque résiduel
T1	Spoofing	E-mail usurpant un manager interne.	Vérification expéditeur et revue humaine.	Compromission réelle de boîte.
T2	Spoofing	Usurpation d'un service interne appelant le moteur.	Authentification service-à-service.	Mauvaise gestion des secrets.
T3	Tampering	Modification du bénéficiaire dans le texte.	Extraction visible et validation bénéficiaire.	Formulation ambiguë.
T4	Tampering	Injection d'un champ JSON non prévu.	Schéma JSON strict.	Erreur de parser ou validation permissive.
T5	Tampering	Modification du catalogue d'accès.	Gouvernance du catalogue.	Erreur humaine validée.
T6	Repudiation	Demandeur nie avoir envoyé l'e-mail.	Conservation message source.	Compte e-mail compromis.
T7	Repudiation	Reviewer nie l'approbation.	Horodatage et identité reviewer.	Identifiants reviewer compromis.
T8	Information Disclosure	Fuite des logs d'accès.	RBAC sur logs et minimisation.	Copie non autorisée.

ID	Type	Scénario	Contrôle principal	Risque résiduel
T9	Information Disclosure	Exposition de la blocklist.	Restriction d'accès aux règles.	Fuite interne.
T10	DoS	Flood de la boîte e-mail.	Quotas et filtrage.	Attaque distribuée.
T11	DoS	E-mails très longs saturant l'IA.	Taille maximale et timeout.	Dégradation partielle.
T12	Elevation	Demande vers Domain Admins.	Blocklist.	Mauvaise configuration blocklist.
T13	Elevation	Mapping ressource vers groupe trop permissif.	Revue du catalogue.	Erreur de gouvernance.
T14	Elevation	PEP appelé hors workflow.	Authentification et contrôle d'origine.	Compromission du compte service.
T15	Tampering	Prompt injection dans l'e-mail.	Adversarial Email Guard.	Nouvelle forme d'injection.
T16	Information Disclosure	Modèle IA révèle contexte interne.	Limitation des sorties.	Mauvaise configuration du prompt.
T17	Repudiation	Action AD non liée à une décision.	Certificat de décision.	Action manuelle hors système.
T18	DoS	Saturation de la revue humaine.	Priorisation et alertes.	Accumulation de cas sensibles.

2.21 Critères d'attribution des valeurs de scoring

L'attribution des valeurs aux facteurs *I*, *V*, *E*, *D* et *R* ne repose pas sur une mesure statistique directe, car aucune base historique d'incidents IAM propre au système étudié n'était disponible. Les valeurs ont donc été attribuées selon une logique semi-quantitative, inspirée des approches DREAD, OWASP Risk Rating et NIST SP 800-30 [11], [12]. Cette logique vise à comparer les

scénarios entre eux de manière structurée, sans prétendre produire une probabilité exacte.

Chaque valeur est déterminée à partir de critères opérationnels liés au contexte AegisAIMail :

- la sensibilité de l'actif concerné.
- la position du scénario dans la chaîne de traitement.
- le franchissement éventuel d'une frontière de confiance.
- la facilité d'exploitation.
- la capacité de détection et l'étendue de l'impact potentiel.

Les valeurs les plus élevées sont réservées aux scénarios pouvant compromettre directement la chaîne d'autorisation, altérer les données structurées utilisées par le moteur de décision ou viser des groupes fortement privilégiés.

Le tableau 2.12 présente la grille utilisée pour attribuer les valeurs aux différents facteurs du modèle.

Facteur	Valeur	Interprétation dans AegisAIMail
Impact I	1–2	Effet limité sur le traitement de la demande, sans modification réelle d'un droit sensible.
	3–4	Effet important sur une demande, un bénéficiaire, un groupe ou une décision d'accès.
	5	Effet majeur pouvant conduire à un accès non autorisé, à une élévation de privilèges ou à une compromission directe de la chaîne d'autorisation.
Vraisemblance V	1–2	Scénario peu probable ou nécessitant des conditions particulières.
	3–4	Scénario plausible dans un contexte de demandes par e-mail, notamment en présence d'erreurs humaines, d'usurpation ou de contenu ambigu.
	5	Scénario très probable ou facilement reproductible dans le contexte étudié.
Exploitableté E	1–2	Exploitation difficile, nécessitant un accès technique avancé ou des privilèges préalables.
	3–4	Exploitation réalisable à partir d'un e-mail, d'un contenu structuré, d'une ambiguïté ou d'un point faible du workflow.
	5	Exploitation simple, directe et nécessitant peu de prérequis techniques.
Détection D	1–2	Scénario facilement détectable par validation, journalisation ou contrôle de conformité.
	3–4	Scénario difficile à distinguer d'une demande légitime ou nécessitant une analyse contextuelle.
	5	Scénario très difficile à détecter avant exécution, notamment en cas de manipulation subtile ou d'absence de trace exploitable.
Rayon d'impact R	1–2	Impact limité à une demande isolée ou à un utilisateur unique.
	3–4	Impact pouvant toucher plusieurs demandes, plusieurs utilisateurs ou plusieurs ressources.
	5	Impact systémique ou critique, pouvant toucher des groupes fortement privilégiés ou une partie centrale du système d'information.

Tab. 2.12: Grille d'attribution des valeurs du modèle de scoring semi-quantitatif.

2.21.1 Justification des valeurs attribuées aux scénarios critiques

Cette grille permet de justifier les valeurs affectées aux scénarios. Par exemple, un e-mail usurpant un manager interne reçoit un impact élevé, car il peut influencer directement une décision d'accès. Sa vraisemblance et son exploitableté sont également importantes, car le canal e-mail constitue une entrée naturelle du système et peut être utilisé pour formuler une demande crédible. De même, une injection dans le JSON IAM reçoit un score élevé, car elle touche directement la représentation structurée utilisée par le moteur de décision. Enfin, une demande visant un groupe tel que `Domain Admins` reçoit un rayon d'impact

maximal, car elle concerne un groupe hautement privilégié.

Le tableau 2.13 illustre l'application de cette grille sur les scénarios classés critiques. Il ne remplace pas le scoring détaillé, mais montre la logique utilisée pour attribuer les valeurs les plus élevées.

ID	Scénario	Justification des valeurs élevées
T1	E-mail usurpant un manager interne	L'impact est fixé à 5, car une demande semblant provenir d'un manager peut influencer directement l'octroi d'un accès. La vraisemblance, l'exploitabilité et la difficulté de détection sont fixées à 4, car le scénario peut être réalisé par le canal e-mail et peut ressembler à une demande légitime. Le rayon d'impact est fixé à 4, car l'accès demandé peut concerner plusieurs ressources ou bénéficiaires.
T4	Injection d'un champ JSON	L'impact est fixé à 5, car le JSON IAM représente la donnée structurée utilisée par la chaîne de décision. Une altération de cette structure peut modifier le bénéficiaire, le groupe cible, la durée ou l'action demandée. Les valeurs <i>V</i> , <i>E</i> et <i>D</i> sont fixées à 4, car l'attaque est plausible dans un flux manipulant des données extraites automatiquement, et sa détection nécessite une validation stricte du schéma.
T12	Demande vers Domain Admins	L'impact est fixé à 5 et le rayon d'impact à 5, car le groupe visé est hautement privilégié. La vraisemblance est maintenue à 3, car ce scénario est moins fréquent qu'une demande standard, mais il reste plausible. L'exploitabilité et la difficulté de détection sont fixées à 4, car la demande peut être formulée comme une demande légitime si le contrôle du groupe cible n'est pas strict.

Tab. 2.13: Justification des valeurs attribuées aux scénarios critiques.

2.22 Scoring détaillé des scénarios

Le tableau 2.14 présente le scoring détaillé des scénarios retenus. Il permet de vérifier la cohérence entre les facteurs définis, les valeurs attribuées, le score obtenu et le niveau de risque associé.

ID	Scénario	I	V	E	D	R	Score	Niveau
T1	E-mail usurpant un manager interne	5	4	4	4	4	87	Critique
T2	Usurpation d'un service interne	4	4	4	3	3	73	Élevé
T3	Modification du bénéficiaire	4	3	4	3	3	67	Élevé
T4	Injection d'un champ JSON	5	4	4	4	4	87	Critique
T5	Modification du catalogue d'accès	4	3	4	4	4	71	Élevé
T6	Répudiation du demandeur	3	3	3	3	2	58	Moyen
T7	Répudiation d'un reviewer	3	2	3	3	3	51	Moyen
T8	Fuite des logs	3	2	3	3	3	55	Moyen
T9	Fuite de la blocklist	3	2	3	3	2	53	Moyen
T10	Flood de la boîte e-mail	3	4	4	2	3	67	Élevé
T11	Saturation IA par texte long	3	3	3	2	3	56	Moyen
T12	Demande vers Domain Admins	5	3	4	4	5	84	Critique
T13	Mapping trop permissif	4	3	4	4	4	71	Élevé
T14	PEP appelé hors workflow	4	3	4	4	4	71	Élevé
T15	Prompt injection visant les règles	4	4	3	3	3	72	Élevé
T16	Fuite par réponse IA	3	3	3	3	2	56	Moyen
T17	Action AD sans certificat	4	2	3	4	3	62	Moyen
T18	Saturation de la revue humaine	3	3	3	3	3	60	Moyen

Tab. 2.14: Scoring détaillé des scénarios de menace selon les facteurs définis dans le modèle semi-quantitatif proposé.

2.23 Contrôles Zero Trust applicables

Un contrôle de sécurité est une mesure organisationnelle, technique ou procédurale visant à réduire un risque. Dans le contexte Zero Trust, les contrôles ne doivent pas être concentrés sur un seul point. Ils doivent accompagner toute la chaîne de décision.

Dans AegisAIMail, les contrôles retenus sont : deny-by-default, validation JSON, allow-list, blocklist, revue humaine, limitation de durée, révocation et audit.

Le tableau 2.15 synthétise les contrôles Zero Trust applicables au système étudié. Il relie chaque mesure à sa définition et à son application concrète dans AegisAIMail.

Tab. 2.15: Contrôles Zero Trust appliqués à AegisAIMail, alignés avec les principes du NIST SP 800-207 [1].

Contrôle	Définition	Application dans AegisAIMail
Deny-by-default	Refuser par défaut ce qui n'est pas explicitement conforme.	Une demande incomplète, ambiguë ou hors catalogue n'est pas exécutée.
Allowlist	Liste des ressources ou groupes explicitement autorisés.	Seuls les groupes autorisés peuvent être provisionnés automatiquement.
Blocklist	Liste des ressources ou groupes interdits.	Les groupes critiques sont bloqués par principe.
Validation JSON	Vérification de la structure et des champs attendus.	Les champs inconnus ou non conformes sont rejetés.
Revue humaine	Intervention d'un responsable pour les cas incertains.	Les demandes à risque élevé sont orientées vers validation humaine.
Limitation de durée	Réduction de l'exposition temporelle d'un droit.	Une demande sans durée claire n'est pas exécutée automatiquement.
Révocation	Retrait d'un accès après expiration ou non-conformité.	L'accès temporaire doit pouvoir être retiré et tracé.
Audit	Conservation des traces de décision et d'action.	Le système conserve la demande, l'extraction, la décision et l'action.

2.24 Cadre conceptuel appliqué à AegisAIMail

Les concepts précédents peuvent être reliés dans une chaîne unique. AegisAIMail reçoit un e-mail non fiable, utilise l'IA pour structurer la demande, valide les champs, applique une décision fondée sur politiques, exécute uniquement les actions autorisées et conserve les traces nécessaires à l'audit.

La figure 2.4 présente cette chaîne. Elle représente la démarche proposée dans ce mémoire.

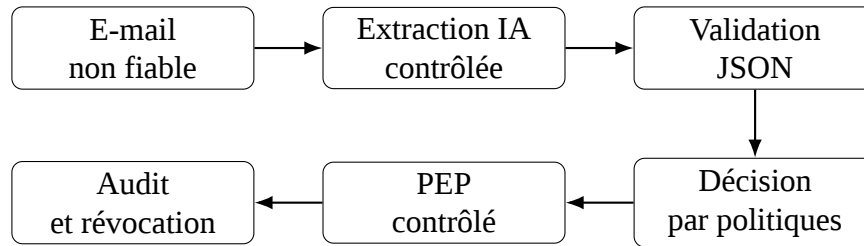


Fig. 2.4: Figure représentant la chaîne conceptuelle de traitement sécurisé dans AegisAIMail.

Cette chaîne résume le principe central du mémoire : l'IA assiste la compréhension, mais la sécurité repose sur la validation, les politiques, le contrôle d'exécution et l'audit.

2.25 Conclusion

Ce chapitre a présenté les fondements conceptuels nécessaires à l'analyse de sécurité du système étudié. Il a d'abord clarifié les notions d'identité numérique, d'authentification, d'autorisation, de contrôle d'accès et d'Access Management. Cette distinction permet de situer AegisAIMail dans son périmètre réel : il ne s'agit pas d'une plateforme IAM complète, mais d'un orchestrateur d'Access Management dédié au traitement sécurisé des demandes d'accès temporaires.

Le chapitre a ensuite présenté les modèles de contrôle d'accès RBAC, ABAC et policy-based. Ces modèles permettent de comprendre la logique retenue dans le système : les groupes d'accès relèvent d'une approche proche du RBAC, tandis que la décision d'accès prend aussi en compte des éléments contextuels tels que l'identité du bénéficiaire, la ressource demandée, la durée, la justification et la sensibilité de l'accès. L'approche fondée sur politiques permet ainsi de séparer l'analyse de la demande, la décision de sécurité et l'exécution technique.

La notion d'accès temporaire a montré que le risque ne dépend pas seulement du privilège accordé, mais aussi de sa durée, de sa justification et de sa révocation. Un accès temporaire non contrôlé peut devenir un privilège persistant, ce qui justifie l'importance de la limitation temporelle, de l'expiration automatique, de la révocation et de l'audit.

Le chapitre a également introduit le modèle Zero Trust comme cadre de sécurité général. Son principe central, l'absence de confiance implicite, est particulièrement adapté au contexte d'AegisAIMail. Une demande reçue par e-mail ne doit pas être considérée comme fiable uniquement parce qu'elle semble provenir d'un utilisateur interne. De même, une sortie produite par l'IA ne doit pas être interprétée comme une décision d'autorisation.

L'utilisation de l'intelligence artificielle a été présentée comme un moyen d'assistance à l'extraction et à la structuration des demandes non structurées. Cependant, l'IA peut produire des erreurs, mal interpréter certaines informations ou être exposée à des entrées malveillantes. Pour cette raison, le système étudié sépare strictement l'extraction IA, la validation, la décision de sécurité et l'exécution.

Enfin, le chapitre a introduit la modélisation des menaces à travers les DFD et la méthode STRIDE, ainsi que l'évaluation semi-quantitative du risque. Ce choix méthodologique permet d'analyser les menaces de manière structurée, sans prétendre produire une mesure probabiliste exacte. Le cadre retenu repose donc sur une chaîne claire : l'e-mail est une entrée non fiable, l'IA structure la demande, la validation contrôle, la politique décide, le PEP exécute et l'audit prouve.

Ainsi, ce chapitre montre que la sécurité d'AegisAIMail ne peut pas être réduite à un problème de classification d'e-mails ou de performance d'un modèle IA. Elle doit être étudiée comme une problématique d'Access Management sécurisé, combinant Zero Trust, threat modeling, scoring du risque, validation contrôlée et auditabilité. Le chapitre suivant s'appuie sur ce cadre pour analyser les travaux existants et positionner la contribution du mémoire.

Chapitre 3

État de l’art

3.1 Introduction

Ce chapitre présente une revue critique des travaux, cadres méthodologiques et standards liés à la sécurisation d’un orchestrateur d’Access Management assisté par intelligence artificielle. L’objectif n’est pas de lister des technologies, mais d’identifier les approches existantes, leurs apports, leurs limites et leur pertinence pour le cas étudié.

Le mémoire se situe à l’intersection de plusieurs domaines : la gestion des identités et des accès, les accès temporaires, l’architecture Zero Trust, la sécurité des systèmes assistés par IA, la modélisation des menaces et le scoring semi-quantitatif du risque. Cette intersection constitue précisément l’intérêt du sujet, car les travaux existants abordent souvent ces domaines séparément.

Le chapitre est structuré en plusieurs parties. Il présente d’abord les approches IAM et Access Management, puis les modèles Zero Trust et Just-in-Time Access. Il analyse ensuite les risques liés à l’usage de l’IA dans une chaîne de décision de sécurité. Il compare enfin les méthodes de threat modeling et les approches de scoring du risque avant de positionner la contribution de ce mémoire.

3.2 Sécurité IAM et Access Management

Les systèmes IAM constituent une brique centrale de sécurité dans les organisations. Ils permettent de gérer les identités numériques, les comptes, les droits, les rôles et les traces

d'activité. Dans les environnements modernes, ils ne se limitent plus à l'administration des utilisateurs internes. Ils doivent également gérer les prestataires, les comptes techniques, les accès distants, les applications cloud et les demandes temporaires.

Les modèles classiques de contrôle d'accès, tels que RBAC et ABAC, ont largement contribué à structurer la gestion des permissions. RBAC simplifie l'administration par l'utilisation de rôles ou de groupes, tandis qu'ABAC permet d'introduire des attributs contextuels dans la décision [5], [6]. Cependant, ces modèles ne résolvent pas seuls la question de l'automatisation sécurisée des demandes d'accès reçues par des canaux non structurés comme l'e-mail.

Le tableau 3.1 compare les approches IAM pertinentes pour le mémoire. Il montre que le cas AegisAIMail ne correspond pas à un IAM complet, mais à une orchestration d'Access Management fondée sur des politiques, des contrôles Zero Trust et une logique de limitation temporelle.

Approche	Principe	Apport	Limite pour le cas étudié
IAM classique	Gestion centralisée des identités, comptes et droits.	Structure l'administration des accès.	Peut conserver des privilèges permanents excessifs.
RBAC	Attribution des droits par rôles ou groupes.	Simple et adapté aux groupes Active Directory.	Peu flexible pour les demandes contextuelles.
ABAC	Décision fondée sur des attributs utilisateur, ressource et contexte.	Permet une décision plus fine.	Nécessite des attributs fiables et bien gouvernés.
Policy-Based Access	Décision produite par des règles explicites.	Sépare la demande, la décision et l'exécution.	Dépend de la qualité des politiques définies.

Tab. 3.1: Comparaison des approches IAM et Access Management, élaborée à partir de RBAC [5] et ABAC [6].

Cette comparaison met en évidence une limite importante : les modèles IAM classiques supposent souvent que la demande d'accès est déjà structurée. Or, dans le cas étudié, la demande arrive par e-mail, sous forme de langage naturel. Cela justifie l'usage d'un composant d'analyse, tout en imposant une validation stricte avant toute décision.

3.3 Accès temporaires, PAM et Just-in-Time Access

Les accès temporaires répondent au problème des privilèges persistants. Dans de nombreuses organisations, des droits sont accordés pour répondre à un besoin ponctuel, mais ne sont pas toujours retirés après usage. Ce phénomène augmente la surface d'attaque et peut faciliter les mouvements latéraux ou l'élévation de privilèges.

Le Privileged Access Management vise à sécuriser les comptes et accès privilégiés. Le Just-in-Time Access cherche, quant à lui, à accorder un droit uniquement pendant la période nécessaire. Cette logique réduit l'exposition temporelle et renforce le principe du moindre privilège.

Toutefois, la mise en œuvre d'un accès temporaire sécurisé exige plusieurs conditions : identification du bénéficiaire, validation de la ressource, justification, durée limitée, décision traçable et révocation effective. Une demande incomplète ou ambiguë ne doit pas être exécutée automatiquement.

Le tableau 3.2 présente la différence entre l'accès permanent, l'accès temporaire et le modèle JIT. Cette distinction est importante pour comprendre pourquoi AegisAIMail se concentre sur les demandes temporaires plutôt que sur une gestion générale de tous les droits.

Type d'accès	Caractéristiques	Risque principal
Accès permanent	Droit accordé sans date de fin.	Accumulation de privilèges et oubli de révocation.
Accès temporaire	Droit accordé pour une durée limitée.	Dépend fortement de la fiabilité de l'expiration.
Just-in-Time Access	Droit accordé au moment du besoin, puis retiré.	Nécessite une orchestration fiable et auditable.
PAM	Contrôle renforcé des comptes et actions privilégiés.	Peut être lourd pour des demandes métier courantes.

Tab. 3.2: Comparaison des formes d'accès dans une logique de réduction des privilèges permanents.

Dans le contexte du mémoire, l'accès temporaire est donc considéré comme un mécanisme de réduction du risque. Cependant, il devient lui-même risqué s'il est automatisé sans garde-fous. Cette observation justifie l'association entre JIT Access, Zero Trust et scoring du risque.

3.4 Zero Trust et décision d'accès

L'architecture Zero Trust, formalisée notamment par le NIST SP 800-207, repose sur l'idée qu'aucune entité ne doit être implicitement fiable [1]. L'accès doit être accordé après vérification explicite de l'identité, du contexte, de la ressource et de la politique applicable.

Dans le domaine de l'Access Management, Zero Trust implique que chaque demande doit être évaluée indépendamment. La localisation réseau ou l'origine interne de la demande ne suffit pas. Cette approche est particulièrement adaptée aux demandes par e-mail, car un message peut être légitime, incomplet, usurpé ou malveillant.

Les travaux autour de BeyondCorp ont également contribué à populariser une vision de la sécurité fondée sur l'identité, le contexte et la vérification continue plutôt que sur la confiance accordée au réseau interne [17]. Cette logique se retrouve dans le cas AegisAI-Mail : l'e-mail n'est jamais considéré comme une preuve suffisante d'autorisation.

Le tableau 3.3 présente les principes Zero Trust les plus importants pour un système d'orchestration d'accès.

Principe Zero Trust	Interprétation en Access Management	Application au cas AegisAI-Mail
Vérification explicite	Chaque demande doit être vérifiée.	Vérification du demandeur, bénéficiaire, groupe cible et durée.
Moindre privilège	Accorder uniquement le droit nécessaire.	Limitation par catalogue, allow-list et blocklist.
Deny-by-default	Refuser par défaut ce qui n'est pas conforme.	Les demandes incomplètes ou hors politique ne sont pas exécutées.
Décision fondée sur politiques	La décision doit être explicite et contrôlable.	Moteur de politiques séparé de l'IA.
Audit continu	Les décisions doivent être traçables.	Journalisation de la demande, du JSON, de la décision et de l'action.

Tab. 3.3: Principes Zero Trust applicables à l'Access Management, d'après NIST SP 800-207 [1].

Cette analyse montre que Zero Trust ne doit pas être compris comme un simple choix d'architecture réseau. Dans ce mémoire, il est utilisé comme principe de gouvernance de la décision d'accès : l'IA peut aider à comprendre, mais seule une politique explicite peut

autoriser.

3.5 Intelligence artificielle et automatisation des demandes d'accès

L'intelligence artificielle permet de traiter des demandes en langage naturel, ce qui est particulièrement utile lorsque les utilisateurs formulent leurs besoins par e-mail. Elle peut aider à classifier une demande, extraire des champs, détecter une intention ou identifier une ambiguïté.

Cependant, l'utilisation de l'IA dans un processus d'accès introduit une difficulté majeure : une sortie de modèle peut être incorrecte, incomplète ou manipulée. Les cadres récents comme le NIST AI Risk Management Framework insistent sur la nécessité de gérer les risques de l'IA à travers la gouvernance, la cartographie, la mesure et la gestion continue [7], [18]. Ces principes sont essentiels dans un système où une mauvaise interprétation peut conduire à un octroi d'accès.

Les risques les plus pertinents dans ce mémoire sont l'hallucination, la mauvaise extraction, l'ambiguïté, la fuite d'information et la prompt injection. Les travaux sur la prompt injection montrent que les modèles peuvent être influencés par des instructions malveillantes insérées dans l'entrée ou dans des sources externes [19], [20].

Dans AegisAIMail, ces risques justifient une règle fondamentale : l'IA ne doit jamais être considérée comme une autorité d'accès. Elle fournit une extraction ou une structuration, mais la validation, la décision et l'exécution doivent être assurées par des composants déterministes et audités.

3.6 Prompt injection et sécurité des applications LLM

La prompt injection est l'un des risques les plus importants dans les applications intégrant des modèles de langage. Elle consiste à insérer dans l'entrée utilisateur des instructions destinées à modifier le comportement attendu du modèle. Dans un système connecté à des outils ou à des actions réelles, ce risque devient critique.

Les travaux de Perez et Ribeiro ont montré que des instructions simples peuvent influen-

cer le comportement d'un modèle [19]. Les travaux de Greshake et al. ont approfondi le risque d'injection indirecte dans des applications intégrées à des sources externes [20]. Ces recherches sont particulièrement pertinentes pour un système qui lit des e-mails, car l'e-mail constitue une source externe non fiable.

Le tableau 3.4 présente les risques IA les plus pertinents pour AegisAIMail et les contrôles associés.

Risque IA	Description	Contrôle recommandé
Prompt injection	L'e-mail contient une instruction malveillante destinée au modèle.	Séparation données/instructions et garde-fou adversarial.
Hallucination	Le modèle produit une information non présente dans l'e-mail.	Extraction limitée aux champs visibles et validation stricte.
Sortie non conforme	Le JSON généré contient des champs inattendus ou mal formés.	Schéma JSON strict et rejet des champs non autorisés.
Fuite d'information	Le modèle expose des groupes, règles ou données internes.	Minimisation des sorties et protection des journaux.
Sur-automatisation	Une sortie IA déclenche une action réelle sans contrôle.	Décision par politiques et PEP contrôlé.

Tab. 3.4: Risques IA pertinents pour un orchestrateur d'accès, d'après NIST AI RMF [7], [18] et OWASP LLM Top 10 [21].

Cette analyse montre que l'enjeu n'est pas seulement d'obtenir une bonne performance de classification ou d'extraction. L'enjeu principal est de maîtriser l'impact d'une erreur ou d'une manipulation du modèle dans une chaîne pouvant aboutir à une action d'accès.

3.7 Threat modeling : méthodes existantes

La modélisation des menaces permet d'identifier les attaques possibles avant qu'elles ne soient exploitées. Elle repose généralement sur la compréhension du système, l'identification des actifs, la représentation des flux, l'analyse des frontières de confiance et la classification des menaces.

Le NIST SP 800-154 présente le threat modeling comme une approche structurée d'identification et d'analyse des menaces [8]. Plusieurs méthodes sont utilisées dans la littérature et dans l'industrie : STRIDE, PASTA, Attack Trees et LINDDUN.

STRIDE est adaptée aux systèmes logiciels représentés par des DFD. PASTA propose

une démarche orientée risque et scénario d’attaque [22]. Les Attack Trees modélisent les chemins possibles vers un objectif d’attaque. LINDDUN est davantage orientée vers la protection de la vie privée et les menaces liées aux données personnelles [23].

Le tableau 3.5 compare ces méthodes selon leur objectif et leur adéquation avec le cas AegisAIMail.

Méthode	Objectif	Avantage	Limite pour AegisAIMail
STRIDE	Classer les menaces logicielles.	Simple, compatible avec les DFD.	Ne fournit pas directement un score de risque.
PASTA	Relier menaces, attaques et risque métier.	Approche complète et orientée attaquant.	Plus lourde à appliquer dans un mémoire limité.
Attack Trees	Décomposer les chemins d’attaque.	Bonne visualisation des scénarios.	Peut devenir complexe pour une chaîne multi-composants.
LINDDUN	Identifier les menaces à la vie privée.	Pertinente pour les données personnelles.	Moins centrée sur l’élévation de privilège et l’IAM.

Tab. 3.5: Comparaison des méthodes de threat modeling, à partir de Shostack [9], Shevchenko et al. [10], PASTA [22] et LINDDUN [23].

Le choix de STRIDE est donc cohérent avec le mémoire. AegisAIMail peut être représenté par un DFD, les frontières de confiance sont clairement identifiables, et les catégories STRIDE couvrent les principaux risques : usurpation, altération, répudiation, divulgation, saturation et élévation de privilèges.

3.8 MITRE ATLAS et menaces contre les systèmes d’IA

Les systèmes assistés par IA peuvent également être analysés à travers des bases de connaissance spécialisées comme MITRE ATLAS. MITRE ATLAS recense des techniques adversariales visant les systèmes d’intelligence artificielle et complète les approches classiques de cybersécurité [24].

Dans le cadre de ce mémoire, MITRE ATLAS n’est pas utilisé comme méthode principale de threat modeling. Il sert plutôt de référence complémentaire pour rappeler que les composants IA possèdent une surface d’attaque spécifique. Cette surface inclut notamment la

manipulation des entrées, l’abus du modèle, l’extraction d’informations et les attaques sur la chaîne de traitement.

Cette référence renforce la justification de l’analyse IA dans le mémoire. Elle montre que l’usage de l’intelligence artificielle dans un système de sécurité ne doit pas être traité uniquement comme une question de performance, mais comme une surface d’attaque à part entière.

3.9 Méthodes de scoring du risque

L’identification des menaces ne suffit pas pour orienter les décisions de sécurité. Il faut également prioriser les risques. Plusieurs approches existent : DREAD, OWASP Risk Rating, CVSS, NIST SP 800-30 et ISO/IEC 27005.

DREAD propose une notation multi-facteurs historiquement utilisée dans le threat modeling. Elle évalue notamment les dommages, la reproductibilité, l’exploitabilité, les utilisateurs affectés et la découvrabilité. OWASP Risk Rating combine des facteurs de vraisemblance et d’impact [12]. CVSS est un standard reconnu pour évaluer les vulnérabilités techniques [13]. NIST SP 800-30 fournit un cadre général d’évaluation du risque [11]. ISO/IEC 27005 fournit des lignes directrices pour la gestion du risque de sécurité de l’information [14].

Le tableau 3.6 compare ces approches. Il montre pourquoi le mémoire retient une méthode semi-quantitative adaptée plutôt qu’une application directe d’un seul référentiel.

Approche	Nature	Forces	Limites
DREAD	Multi-facteurs.	Simple et pédagogique.	Subjectivité élevée et usage moins standardisé.
OWASP Risk Rating	Vraisemblance et impact.	Adapté aux applications web et aux risques applicatifs.	Nécessite adaptation au contexte IAM.
CVSS	Scoring technique de vulnérabilités.	Standard reconnu et structuré.	Moins adapté aux scénarios métier ou processus.
NIST SP 800-30	Cadre général de gestion du risque.	Méthodologiquement solide.	Ne donne pas une formule spécifique au cas étudié.
ISO/IEC 27005	Gestion du risque SSI.	Cadre reconnu en gouvernance sécurité.	Niveau général, dépend du contexte organisationnel.

Tab. 3.6: Comparaison des approches de scoring du risque, d’après OWASP [12], CVSS [13], NIST SP 800-30 [11] et ISO/IEC 27005 [14].

Dans ce mémoire, le scoring proposé est donc assumé comme semi-quantitatif. Il vise à classer les scénarios, non à produire une probabilité exacte. Cette position est cohérente avec l’absence d’une base statistique d’incidents réels et avec l’usage d’une validation experte.

3.10 Auditabilité et non-répudiation

L’auditabilité est une dimension essentielle des systèmes d’accès. Un système qui modifie des droits doit pouvoir justifier ses décisions et permettre une reconstruction complète du traitement. Cette exigence est encore plus importante lorsque l’IA intervient dans la chaîne, car il faut distinguer ce que le modèle a extrait de ce que le moteur de décision a autorisé.

Le NIST SP 800-53 accorde une place importante aux contrôles d’audit, de responsabilité et de protection des traces [25]. Dans le contexte AegisAIMail, ces contrôles se traduisent par la conservation de l’e-mail initial, du JSON extrait, du résultat de validation, de la décision, de l’action du PEP et de l’état de révocation.

Le tableau 3.7 présente les informations minimales nécessaires pour rendre une décision

d'accès auditable.

Élément auditable	Rôle dans la preuve de décision
E-mail initial	Prouver l'origine et le contenu de la demande.
Extraction IA	Identifier les champs interprétés par le modèle.
JSON valide	Montrer la structure réellement transmise à la décision.
Règle appliquée	Justifier l'état final de la demande.
Décision	Tracer l'autorisation, la clarification, le refus ou le blocage.
Action PEP	Prouver l'action technique réellement exécutée.
Révocation	Prouver le retrait de l'accès temporaire.

Tab. 3.7: Éléments nécessaires à l'auditabilité d'une décision d'accès, alignés avec les contrôles d'audit du NIST SP 800-53 [25].

L'auditabilité ne doit donc pas être considérée comme une simple fonctionnalité secondaire. Dans un système d'accès automatisé, elle constitue une condition de confiance, de conformité et de non-répudiation.

3.11 Synthèse critique de l'état de l'art

L'analyse des travaux existants montre que chaque domaine apporte une partie de la réponse. L'IAM fournit les bases de la gestion des droits. Zero Trust impose une vérification explicite et une absence de confiance implicite. Les approches JIT réduisent l'exposition temporelle des privilèges. Les cadres IA identifient les risques liés aux modèles. STRIDE structure l'identification des menaces. Les méthodes de scoring permettent de prioriser les risques. Enfin, l'auditabilité garantit la preuve de décision.

Cependant, ces approches restent souvent séparées. Peu de travaux traitent spécifiquement le cas d'un système où une demande d'accès temporaire arrive par e-mail, est analysée par IA, transformée en JSON, évaluée par politiques, puis potentiellement exécutée dans un annuaire d'entreprise.

Le tableau 3.8 synthétise les limites observées dans la littérature par rapport au sujet du mémoire.

Domaine	Apport	Limite par rapport au mémoire
IAM / RBAC / ABAC	Modèles de gestion des droits.	Supposent souvent des demandes structurées.
JIT / PAM	Réduction des privilèges permanents.	Peu centré sur les demandes par e-mail en langage naturel.
Zero Trust	Vérification explicite et moindre privilège.	Doit être adapté à une chaîne assistée par IA.
Sécurité IA / LLM	Identification des risques de prompt injection et hallucination.	Ne traite pas directement l'octroi d'accès IAM.
STRIDE	Identification systématique des menaces.	Ne fournit pas de priorisation native.
Scoring du risque	Classement des risques.	Nécessite une adaptation au contexte IAM et IA.
Auditabilité	Traçabilité et non-répudiation.	Doit être reliée au pipeline IA et aux décisions d'accès.

Tab. 3.8: Synthèse critique des limites de l'état de l'art par rapport au cas AegisAIMail.

Cette synthèse permet de justifier la contribution du mémoire : proposer une lecture intégrée combinant Zero Trust, STRIDE, scoring semi-quantitatif et validation experte pour un orchestrateur d'accès assisté par IA.

3.12 Positionnement de la contribution

La contribution du mémoire ne consiste pas à inventer une nouvelle méthode de threat modeling à partir de zéro. Elle consiste à adapter et combiner des approches reconnues pour un cas précis et sensible : le traitement automatisé de demandes d'accès temporaires par e-mail.

Le positionnement retenu est le suivant :

- l'e-mail est considéré comme une entrée non fiable ;
- l'IA est limitée à un rôle d'extraction et de structuration ;
- la décision est produite par des politiques explicites ;
- STRIDE est utilisé pour identifier les menaces ;
- le scoring semi-quantitatif permet de prioriser les scénarios ;
- les contrôles Zero Trust réduisent le risque d'exécution non autorisée ;

- l’auditabilité permet de conserver une preuve de décision.

Cette combinaison donne au mémoire une valeur académique et opérationnelle. Elle montre comment sécuriser une chaîne d’orchestration d’accès sans déléguer la décision de sécurité au modèle IA.

3.13 Conclusion du chapitre

Ce chapitre a analysé les principaux travaux et cadres existants liés au sujet. L’étude de l’IAM et des modèles de contrôle d’accès a montré que la gestion des droits doit être complétée par des politiques contextuelles lorsque les demandes sont temporaires et formulées en langage naturel. L’analyse du Zero Trust a établi que l’absence de confiance implicite, la vérification explicite, le moindre privilège et la traçabilité sont indispensables pour encadrer l’automatisation d’un accès.

L’étude des risques IA a montré que l’intégration d’un modèle dans une chaîne d’accès ne doit pas être évaluée uniquement selon sa performance. Les risques de prompt injection, d’hallucination, de sortie non conforme et de fuite d’information imposent une séparation stricte entre extraction, validation, décision et exécution. Cette séparation constitue un principe central du mémoire.

La comparaison des méthodes de threat modeling a justifié le choix de STRIDE, car AegisAIMail peut être représenté par un DFD clair et des frontières de confiance identifiables. En revanche, STRIDE ne fournit pas de mécanisme de priorisation. C’est pourquoi le mémoire complète cette méthode par un scoring semi-quantitatif inspiré de DREAD et de l’OWASP Risk Rating, tout en s’appuyant sur la prudence méthodologique des cadres NIST et ISO.

L’état de l’art montre finalement une lacune : les approches existantes traitent séparément l’IAM, le Zero Trust, l’IA, le threat modeling et le scoring du risque. Le présent mémoire propose de les combiner dans une démarche cohérente appliquée à un orchestrateur d’Access Management assisté par IA. Cette démarche permet d’analyser les menaces, de prioriser les scénarios, de définir des contrôles Zero Trust et de discuter le risque résiduel d’un système tel qu’AegisAIMail.

Le chapitre suivant présentera la conclusion générale du mémoire et les perspectives. Il

synthétisera les apports obtenus, les limites de l'approche et les pistes d'amélioration possibles pour une validation plus large en environnement opérationnel.

Chapitre 4

Conclusion générale et perspectives

Ce dernier chapitre clôt le mémoire en synthétisant les principaux résultats obtenus, les apports de l'analyse proposée, les limites rencontrées ainsi que les perspectives d'amélioration. Il revient d'abord sur la démarche menée autour de l'analyse Zero Trust, de la modélisation STRIDE, du scoring semi-quantitatif et de la revue experte qualitative. Il présente ensuite les contributions du mémoire, discute les limites méthodologiques et opérationnelles, puis ouvre sur des pistes futures de validation et d'amélioration.

4.1 Conclusion générale

Ce mémoire a porté sur l'analyse de sécurité Zero Trust d'un orchestrateur d'Access Management assisté par intelligence artificielle, destiné au traitement des demandes d'accès temporaires reçues par e-mail. Le travail s'est appuyé sur le système AegisAIMail comme cas d'étude, non pas pour présenter uniquement une réalisation technique, mais pour analyser les risques de sécurité liés à une chaîne dans laquelle une entrée non structurée peut conduire à une décision d'accès.

Le point de départ du mémoire était une problématique précise : comment sécuriser un processus où un e-mail, potentiellement incomplet, ambigu ou malveillant, est analysé par un composant d'intelligence artificielle, transformé en demande structurée, puis évalué par des politiques de sécurité avant une éventuelle action d'accès. Cette problématique est importante, car elle combine plusieurs surfaces de risque : la messagerie, le langage naturel, l'IA, la décision d'accès, le provisioning, l'audit et la révocation.

L'analyse réalisée montre que la sécurisation d'un tel système ne peut pas reposer uniquement sur la performance du modèle d'intelligence artificielle. Même si l'IA peut aider à comprendre et structurer une demande, elle ne doit jamais être considérée comme une autorité d'autorisation. La décision d'accès doit rester sous le contrôle de règles explicites, vérifiables et auditable. Cette séparation entre extraction, validation, décision et exécution constitue l'un des résultats essentiels du mémoire.

Le travail a également montré que l'approche Zero Trust est particulièrement adaptée à ce type de système. Dans AegisAIMail, l'e-mail entrant est traité comme une donnée non fiable, la sortie IA est validée avant toute décision, les accès sont limités par des politiques, les groupes sensibles sont protégés par des garde-fous, et les actions doivent être journalisées. Cette logique est cohérente avec les principes de vérification explicite, de moindre privilège, de deny-by-default et de traçabilité.

La méthode STRIDE a permis d'identifier les principales familles de menaces applicables au système étudié : usurpation d'identité, altération des données, répudiation, divulgation d'information, déni de service et élévation de privilèges. Son utilisation est justifiée par la possibilité de représenter AegisAIMail à travers un diagramme de flux de données, avec des entités externes, des processus, des flux, des magasins de données et des frontières de confiance.

Cependant, STRIDE ne fournit pas à elle seule un mécanisme de priorisation. Pour cette raison, le mémoire a proposé un scoring semi-quantitatif inspiré de DREAD et de l'OWASP Risk Rating. Ce scoring repose sur cinq facteurs adaptés au contexte IAM : l'impact, la vraisemblance, l'exploitabilité, la difficulté de détection et le rayon d'impact. Il ne constitue pas une mesure statistique absolue, mais un outil de priorisation permettant de comparer les scénarios de menace et d'orienter les contrôles de sécurité.

La validation experte joue ici un rôle important. En l'absence d'une base historique d'incidents suffisamment représentative, le recours à une revue experte permet de vérifier la cohérence des facteurs, des pondérations et des seuils utilisés. Cette validation ne supprime pas la subjectivité du scoring, mais elle rend les hypothèses explicites et discutables, ce qui renforce la rigueur de l'analyse.

Les résultats du mémoire montrent que les scénarios les plus critiques concernent principalement l'usurpation de demandeur, l'altération du JSON IAM, les demandes vers des

groupes sensibles, la prompt injection et les erreurs d'extraction pouvant conduire à un accès non conforme. Ces risques justifient l'usage combiné de plusieurs contrôles : validation stricte du JSON, allowlist, blocklist, revue humaine, limitation de durée, audit et révocation.

Ainsi, la contribution principale du mémoire est une démarche structurée d'analyse de sécurité appliquée à un orchestrateur d'accès assisté par IA. Cette démarche combine le DFD, STRIDE, le scoring semi-quantitatif, le mapping des contrôles Zero Trust, la validation experte et l'analyse du risque résiduel. Elle montre que l'automatisation des demandes d'accès par e-mail peut être envisagée uniquement si la décision de sécurité reste maîtrisée, traçable et séparée de l'IA.

4.2 Apports du mémoire

Les apports de ce mémoire peuvent être résumés selon quatre axes.

Le premier apport est la clarification du positionnement d'AegisAIMail. Le système n'est pas présenté comme une plateforme IAM complète, mais comme un orchestrateur d'Access Management destiné au traitement sécurisé de demandes d'accès temporaires. Cette distinction permet de mieux définir le périmètre de sécurité et d'éviter toute confusion entre gestion globale des identités et orchestration contrôlée des accès.

Le deuxième apport est la construction d'un cadre conceptuel adapté. Le mémoire relie les notions d'IAM, de Zero Trust, d'accès temporaires, d'IA, de threat modeling, de scoring et d'auditabilité. Cette combinaison montre que le sujet ne se limite pas à l'application isolée de STRIDE, mais concerne une problématique plus large de sécurisation d'une chaîne d'accès assistée par IA.

Le troisième apport est la proposition d'un scoring semi-quantitatif contextualisé. Les facteurs retenus permettent d'évaluer les scénarios de menace selon leur gravité opérationnelle et leur pertinence dans un environnement IAM. Le score proposé aide à prioriser les risques, tout en gardant une approche prudente et transparente sur ses limites.

Le quatrième apport est l'identification des contrôles Zero Trust nécessaires pour réduire les risques. L'analyse montre que la sécurité repose sur une défense en profondeur : aucune étape ne doit suffire seule à accorder un accès. L'e-mail, l'IA, le JSON, la décision et le

PEP doivent chacun être contrôlés par des mécanismes spécifiques.

4.3 Limites de l'étude

Malgré les apports obtenus, ce mémoire présente plusieurs limites.

La première limite concerne la nature semi-quantitative du scoring. Les pondérations proposées sont cohérentes avec le contexte IAM et ont été discutées par revue experte, mais elles ne reposent pas sur une base statistique d'incidents réels. Le score doit donc être interprété comme un outil de priorisation, et non comme une probabilité exacte.

La deuxième limite concerne le périmètre du système étudié. L'analyse porte sur AegisAI-Mail comme orchestrateur d'accès temporaire par e-mail. Elle ne couvre pas l'ensemble d'une plateforme IAM complète, ni l'audit exhaustif de la messagerie, de l'annuaire ou de l'infrastructure réseau. Certains risques externes, comme la compromission d'une boîte e-mail légitime, dépassent donc le périmètre direct du système.

La troisième limite est liée à l'intelligence artificielle. Les risques de prompt injection, d'hallucination et de mauvaise extraction évoluent rapidement. Les contrôles proposés réduisent ces risques, mais ne les éliminent pas totalement. Une surveillance continue et une réévaluation régulière restent nécessaires.

La quatrième limite concerne la validation du scoring. Le modèle proposé a été discuté dans le cadre d'une revue experte qualitative, mais il n'a pas été calibré sur une base statistique d'incidents réels. Cette limite est liée à l'absence de données historiques représentatives dans le contexte étudié. Le choix d'une approche semi-quantitative permet donc de prioriser les scénarios de manière structurée, sans prétendre fournir une probabilité exacte.

Enfin, la qualité du catalogue d'accès reste un facteur déterminant. Même si la chaîne de décision est sécurisée, un mauvais mapping entre une ressource métier et un groupe technique peut conduire à une décision dangereuse. La gouvernance du catalogue constitue donc une condition essentielle de sécurité.

4.4 Perspectives

Plusieurs perspectives peuvent être envisagées afin de prolonger ce travail.

La première perspective consiste à enrichir la validation du scoring à partir de données réelles ou semi-réelles. Une phase d'observation en mode shadow pourrait permettre de comparer les scores proposés avec les décisions humaines, les incidents détectés et les cas de clarification. Cette démarche aiderait à ajuster les pondérations et les seuils.

La deuxième perspective concerne l'intégration avec des outils de supervision. Les décisions, les scores, les rejets, les blocages et les révocations pourraient être transmis vers un SIEM afin d'améliorer la détection, la corrélation et la réponse aux incidents. Cette intégration permettrait aussi de suivre l'évolution des risques dans le temps.

La troisième perspective consiste à renforcer la sécurité des composants IA. Des tests adversariaux plus systématiques pourraient être menés sur les e-mails malveillants, les injections indirectes, les demandes ambiguës, les formulations multilingues et les tentatives de contournement des règles. Ces tests permettraient d'améliorer les garde-fous contre la prompt injection et la génération de sorties non conformes.

La quatrième perspective porte sur la gouvernance du catalogue d'accès. Un catalogue fiable doit contenir les ressources, les groupes, les privilèges, les propriétaires, la sensibilité et les conditions d'accès. Une mauvaise gouvernance du catalogue peut réduire l'efficacité de tout le système. Il serait donc pertinent d'ajouter des mécanismes de revue périodique des groupes, de classification de sensibilité et de validation par les propriétaires métier.

La cinquième perspective concerne l'extension du canal d'entrée. Même si ce mémoire se concentre sur l'e-mail, la même démarche pourrait être adaptée aux tickets ITSM, aux formulaires, aux portails internes ou aux assistants conversationnels. Chaque canal introduirait de nouvelles menaces et nécessiterait une adaptation du DFD, de STRIDE et des contrôles.

La sixième perspective est l'amélioration du certificat de décision. Un certificat plus complet pourrait inclure l'e-mail initial, les champs extraits, le JSON validé, les règles appliquées, le score calculé, l'état de décision, l'action exécutée et l'état de révocation. Cela renforcerait l'auditabilité, la non-répudiation et la capacité à expliquer les décisions.

Enfin, une perspective importante consiste à formaliser davantage les politiques d'accès. Des règles exprimées dans un langage de politique plus structuré pourraient faciliter la vérification, la maintenance et l'audit. Cette évolution permettrait de réduire les ambiguïtés et d'améliorer la robustesse du moteur de décision.

4.5 Conclusion finale

Ce mémoire a montré qu'un orchestrateur d'Access Management assisté par IA peut être analysé de manière rigoureuse à condition de ne pas réduire le problème à la seule performance du modèle. Dans un processus d'accès, le risque principal réside dans la transformation d'une entrée non fiable en action de sécurité. La réponse proposée repose donc sur une séparation stricte : l'IA structure, la validation contrôle, la politique décide, le PEP exécute et l'audit prouve.

L'approche Zero Trust fournit le cadre de sécurité général. STRIDE permet d'identifier les menaces. Le scoring semi-quantitatif aide à prioriser les scénarios. La revue experte permet de discuter la cohérence des hypothèses. L'analyse du risque résiduel rappelle enfin que la sécurité ne peut jamais être considérée comme totalement acquise.

Ainsi, le mémoire apporte une démarche applicable à AegisAIMail et, plus largement, à tout système cherchant à automatiser des demandes d'accès temporaires à partir de données non structurées. La principale conclusion est que l'intelligence artificielle peut assister l'Access Management, mais elle ne doit pas gouverner seule la décision d'accès. La sécurité doit rester portée par des politiques explicites, des contrôles Zero Trust et une traçabilité complète.

Bibliographie

- [1] S. Rose, O. Borchert, S. Mitchell et S. Connelly, « Zero Trust Architecture », National Institute of Standards et Technology, rapp. tech. NIST Special Publication 800-207, 2020. doi : [10.6028/NIST.SP.800-207](https://doi.org/10.6028/NIST.SP.800-207)
- [2] National Institute of Standards and Technology, *NIST CSRC Glossary : Authentication*, <https://csrc.nist.gov/glossary/term/authentication>, Consulté le 29 juin 2026.
- [3] National Institute of Standards and Technology, *NIST CSRC Glossary : Authorization*, <https://csrc.nist.gov/glossary/term/authorization>, Consulté le 29 juin 2026.
- [4] National Institute of Standards and Technology, *NIST CSRC Glossary : Access Control*, https://csrc.nist.gov/glossary/term/access_control, Consulté le 29 juin 2026.
- [5] D. F. Ferraiolo et D. R. Kuhn, « Role-Based Access Controls », *15th National Computer Security Conference*, p. 554-563, 1992.
- [6] V. C. Hu et al., « Guide to Attribute Based Access Control (ABAC) Definition and Considerations », National Institute of Standards et Technology, rapp. tech. NIST Special Publication 800-162, 2014. doi : [10.6028/NIST.SP.800-162](https://doi.org/10.6028/NIST.SP.800-162)
- [7] National Institute of Standards and Technology, « Artificial Intelligence Risk Management Framework (AI RMF 1.0) », National Institute of Standards et Technology, rapp. tech. NIST AI 100-1, 2023. doi : [10.6028/NIST.AI.100-1](https://doi.org/10.6028/NIST.AI.100-1)
- [8] National Institute of Standards and Technology, « Guide to Data-Centric System Threat Modeling », National Institute of Standards et Technology, rapp. tech. NIST Special Publication 800-154, 2016. doi : [10.6028/NIST.SP.800-154](https://doi.org/10.6028/NIST.SP.800-154)

- [9] A. Shostack, *Threat Modeling : Designing for Security*. Wiley, 2014.
- [10] N. Shevchenko, T. A. Chick, P. O’Riordan, T. P. Scanlon et C. Woody, «Threat Modeling : A Summary of Available Methods», Carnegie Mellon University, Software Engineering Institute, rapp. tech., 2018. doi : [10.1184/R1/7131050.v1](https://doi.org/10.1184/R1/7131050.v1)
- [11] National Institute of Standards and Technology, «Guide for Conducting Risk Assessments», National Institute of Standards et Technology, rapp. tech. NIST Special Publication 800-30 Revision 1, 2012. doi : [10.6028/NIST.SP.800-30r1](https://doi.org/10.6028/NIST.SP.800-30r1)
- [12] OWASP Foundation, *OWASP Risk Rating Methodology*, https://owasp.org/www-community/OWASP_Risk_Rating_Methodology, 2024.
- [13] Forum of Incident Response and Security Teams, *Common Vulnerability Scoring System Version 4.0: Specification Document*, <https://www.first.org/cvss/>, 2023.
- [14] *ISO/IEC 27005:2022 Information Security, Cybersecurity and Privacy Protection – Guidance on Managing Information Security Risks*, International Organization for Standardization, 2022.
- [15] N. Dalkey et O. Helmer, «An Experimental Application of the Delphi Method to the Use of Experts», *Management Science*, t. 9, n° 3, p. 458-467, 1963. doi : [10.1287/mnsc.9.3.458](https://doi.org/10.1287/mnsc.9.3.458) adresse : <https://doi.org/10.1287/mnsc.9.3.458>
- [16] D. Khodyakov, S. Grant, J. Kroger et M. Bauman, «RAND Methodological Guidance for Conducting and Critically Appraising Delphi Panels», RAND Corporation, rapp. tech. TLA3082-1, 2023, Consulté le 29 juin 2026. adresse : <https://www.rand.org/pubs/tools/TLA3082-1.html>
- [17] R. Ward et B. Beyer, «BeyondCorp : A New Approach to Enterprise Security », *login* :, t. 39, n° 6, p. 6-11, 2014.
- [18] National Institute of Standards and Technology, «Artificial Intelligence Risk Management Framework : Generative Artificial Intelligence Profile», National Institute of Standards et Technology, rapp. tech. NIST AI 600-1, 2024. doi : [10.6028/NIST.AI.600-1](https://doi.org/10.6028/NIST.AI.600-1)

- [19] F. Perez et I. Ribeiro, « Ignore Previous Prompt : Attack Techniques For Language Models », *arXiv preprint arXiv :2211.09527*, 2022.
- [20] K. Greshake, S. Abdelnabi, S. Mishra, C. Endres, T. Holz et M. Fritz, « Not What You've Signed Up For : Compromising Real-World LLM-Integrated Applications with Indirect Prompt Injection », in *Proceedings of the 16th ACM Workshop on Artificial Intelligence and Security*, 2023, p. 79-90. doi : [10 . 1145 / 3605764 . 3623985](https://doi.org/10.1145/3605764.3623985)
- [21] OWASP Foundation, *OWASP Top 10 for Large Language Model Applications*, <https://genai.owasp.org/>, 2025.
- [22] T. UcedaVelez et M. M. Morana, *Risk Centric Threat Modeling : Process for Attack Simulation and Threat Analysis*. Wiley, 2015.
- [23] M. Deng, K. Wuyts, R. Scandariato, B. Preneel et W. Joosen, « A Privacy Threat Analysis Framework : Supporting the Elicitation and Fulfillment of Privacy Requirements », *Requirements Engineering*, t. 16, n° 1, p. 3-32, 2011. doi : [10 . 1007 / s00766-010-0115-7](https://doi.org/10.1007/s00766-010-0115-7)
- [24] MITRE, *MITRE ATLAS : Adversarial Threat Landscape for Artificial-Intelligence Systems*, <https://atlas.mitre.org/>, 2025.
- [25] National Institute of Standards and Technology, « Security and Privacy Controls for Information Systems and Organizations », National Institute of Standards et Technology, rapp. tech. NIST Special Publication 800-53 Revision 5, 2020. doi : [10 . 6028 / NIST . SP . 800-53r5](https://doi.org/10.6028/NIST.SP.800-53r5)